Computers & Security 154 (2025) 104419

Contents lists available at ScienceDirect

Computers & Security

journal homepage: www.elsevier.com/locate/cose

Full length article

Robust and reusable LINDDUN privacy threat knowledge

Laurens Sion *, Dimitri Van Landuyt, Kim Wuyts, Wouter Joosen

DistriNet, KU Leuven, Celestijnenlaan 200A, 3001, Leuven, Belgium

ARTICLE INFO

Keywords:
Privacy threat modeling
LINDDUN
Model-driven privacy
Privacy analysis
Privacy by design

ABSTRACT

Privacy threat modeling is an intrinsically complex analysis task that requires expertise in sophisticated privacy threats, their harms and implications, as well as potential mitigations. To support both novices and experts in attaining a desired degree of rigor and completeness in their analysis, supporting materials such as privacy threat trees and threat examples are crucial as they consolidate and harmonize the complete spectrum of threat characteristics, and as such assist with the broader uptake of privacy threat modeling practices.

However, the existing knowledge structures, taxonomies, and trees used in privacy threat analysis prove to have limited use in practice. They are either too broad and generic, or too tightly coupled to a specific modeling approach (DFDS) or to a specific threat elicitation method (e.g., per-element). In addition, current privacy threat knowledge structures suffer from semantic ambiguity. Finally, existing structures are too rigid to support evolution, thus hindering the incorporation of emerging privacy threats.

This article introduces three contributions to address these shortcomings: (i) it defines the metamodel to express threat knowledge in the form of threat types, elicitation criteria, examples, and additional metadata; (ii) it discusses its application to the privacy threat knowledge of the LINDDUN privacy threat modeling framework; and (iii) it introduces the automated knowledge management tools comprised of extraction logic that allows more flexible adoption in different privacy analysis approaches, and that fundamentally supports continuous evolution and refinement of this privacy threat knowledge. A major outcome is the updated LINDDUN privacy threat knowledge which completely subsumes earlier versions and provides more rooted support for adoption, refinement, and continuous evolution.

1. Introduction

Threat modeling or threat analysis refers to the up-front analytical assessment of viability, impact and implications of common problems – threats – in the design of a system. This analysis activity helps the architect or developer with identifying and implementing appropriate measures to mitigate the identified threats. Methods and techniques related to threat modeling have recently gained more attention and recognition as an essential step in the development life-cycle to design privacy-preserving and secure software systems (Braiterman et al., 2020). Threat modeling approaches have emerged significantly in the context of security design analysis in the early 2000s (Kohnfelder and Garg, 1999; Swiderski and Snyder, 2004; Howard and Lipner, 2006; Shostack, 2014a). However, extensions and approaches for identifying privacy threats have also emerged, of which LINDDUN is widely recognized because of its maturity and completeness (Deng et al., 2011), in part due to its characterization of privacy issues in the form of threat trees that provide refinement of generic threat types into more concrete issues. The remainder of this article will use 'threat modeling' as a shorthand for privacy threat modeling.

Privacy is a complex notion related to security, yet with its very own intrinsicalities that go beyond just preserving the confidentiality of (personal) data. LINDDUN itself, is an acronym of the different threat types considered: Linking, Identifying, Non-repudiation, Detecting, Data Disclosure, Unawareness & Unintervenability, and Non-compliance. Privacy threats refer to inherently complex concepts (such as 'unlinkability of data or actions', 'intervenability', or 'attributability of actions to individuals') and these are often underestimated and misunderstood by non-experts.

The application of privacy threat analysis therefore requires significant effort and expertise and remains daunting to novice users. To aid practitioners, threat modeling approaches typically provide knowledge resources such as threat trees (Deng et al., 2011), threat cards (Wuyts et al., 2020) or threat catalogs that help in (i) furthering the understanding of the complex privacy design issues that must be considered (education and awareness), and (ii) applying such knowledge to a

* Corresponding author.
E-mail addresses: laurens.sion@kuleuven.be (L. Sion), dimitri.vanlanduyt@kuleuven.be (D. Van Landuyt), kim.wuyts@kuleuven.be (K. Wuyts), wouter.joosen@kuleuven.be (W. Joosen).

https://doi.org/10.1016/j.cose.2025.104419
Received 12 November 2024; Received in revised form 13 February 2025; Accepted 5 March 2025
Available online 26 March 2025
0167-4048/© 2025 Elsevier Ltd. All rights are reserved, including those for text and data mining, AI training, and similar technologies.

concrete application to identify relevant and specific application threats (application and elicitation). The consolidation of expert knowledge on privacy threats and risks in accessible and well-defined resources is a key enabler for any privacy-by-design effort.

In this article, we highlight and address the problems with the state-of-the-art privacy threat knowledge structures: rigidity, tight coupling to the modeling approach or the elicitation method, and semantic ambiguity.

This article provides the following three contributions. First, we make this problem more concrete and illustrate it in the knowledge resources that until recently have underpinned LINDDUN, the currently most widely known and complete privacy threat modeling approach (in the literature (Xiong and Lagerström, 2019), through variants and tool support (Barberá, 2024; OWASP, 2025), and standards (International Organization for Standardization, 2019, 2023)). More specifically, we focus on the problems encountered in privacy threat trees (Wuyts, 2015) and threat cards (Wuyts et al., 2020) that each encode some form of privacy threat knowledge in a suboptimal manner. Such encodings are representative as illustrated by similar representations for security threat trees (Howard and Lipner, 2006; Shostack, 2014a) or cards (Shostack, 2014b). We introduce a metamodel to capture this threat knowledge in a rigorous and more principled way.

Second, we present new model-driven tool enablers for structuring the threat knowledge structures as a product line, fundamentally enabling the automated derivation of variants suited for different usage scenarios and fit for adoption by different stakeholder types. As these variants draw from the same knowledge models, and supported by the extensive degree of automation in the model-driven extraction, they can now be continually kept up to date with future evolutions in the threat knowledge models.

Third, we present the outcome of applying this more rooted approach to the LINDDUN threat knowledge models, and we discuss their establishment and in-depth validation at the basis of challenging example cases and three real-world application cases. We further evaluate these new LINDDUN threat knowledge structures by quantifying the degree of agreement among practitioners that explicitly apply LINDDUN threat elicitation with the updated threat knowledge structures, in comparison to earlier versions of the privacy threat knowledge, and we show an improvement in reproducibility of privacy threat analysis outcomes (higher degree of practitioner agreement).

We present the construction of new threat knowledge structures, and establish a more fundamental underpinning in a model-driven framework. This framework (i) is harnessed for extension and refinement by enabling evolution and actualization of the threat knowledge in light of new privacy threats; and (ii) it does not prescribe an approach but is versatile for reuse across multiple threat modeling approaches. While this framework and approach have been specifically applied to LINDDUN, they can be adopted and applied to other threat knowledge efforts, for example those supporting the STRIDE for security threat modeling.

This article is structured as follows. First Section 2 motivates the contributions by illustrating the problems with the existing LINDDUN trees and derives key requirements for structuring threat knowledge. Then, Section 3 presents the overall approach to construct modeling support and leveraging it for representing the LINDDUN privacy threat knowledge. Sections 4 to 7 subsequently discuss the metamodel construction, the application to LINDDUN, validation of the flexibility dimensions from the motivation, and the evaluation of practitioner agreement. Section 8 discusses related work, and finally, Section 9 concludes the article.

2. Motivation

Privacy threat modeling a system involves the in-depth analysis of potential privacy risks and threats incurred by that system and its design. A threat modeling analysis starts from an in-depth characterization of the system under design, which is then subjected to a systematic effort to identify relevant threats. A *threat* in its simplest interpretation is a concrete scenario with negative privacy consequences. These are then prioritized and mitigated.

The broader notion of privacy as an engineering or design objective is often incorrectly reduced to the narrower system goal of confidentiality — ensuring that sensitive data records are sufficiently protected. However, a privacy threat modeling expert looks at privacy implications that go well beyond purely data leakage (loss of confidentiality). For example, a system may impact the plausible deniability of a user, i.e. losing the ability to deny having a positive covid test in a contact tracing application. Or, in another example, not providing the data subject with sufficient controls to inspect, erase, or rectify personal data is an unawareness and unintervenability issue as the data subject lacks transparency about and control over the data processing. Privacy threat analysis is thus inherently a sophisticated and highly specialized effort. From a practitioner perspective, relying upon a comprehensive source or reference of privacy threat knowledge is therefore crucial.

In the LINDDUN threat modeling framework, the privacy threat knowledge is represented in different artifact types such privacy threat trees or cards. Threat trees are hierarchical structures that further refine the broader threat types. Fig. 1(a) depicts an example of LINDDUN threat tree (just one of many), specifically for investigating *Identifiability* threats at the level of a data flow (Wuyts et al., 2014). Fig. 1(b) shows the card-based representation of similar threat knowledge in the card-based LINDDUN GO variant. Hierarchical tree-based representations such as the STRIDE trees (Shostack, 2014a) and the prior LINDDUN encoding of trees (Wuyts, 2015) and threat cards (Wuyts et al., 2020) are hard-coded, and not amenable to change, extension and programmatic access.

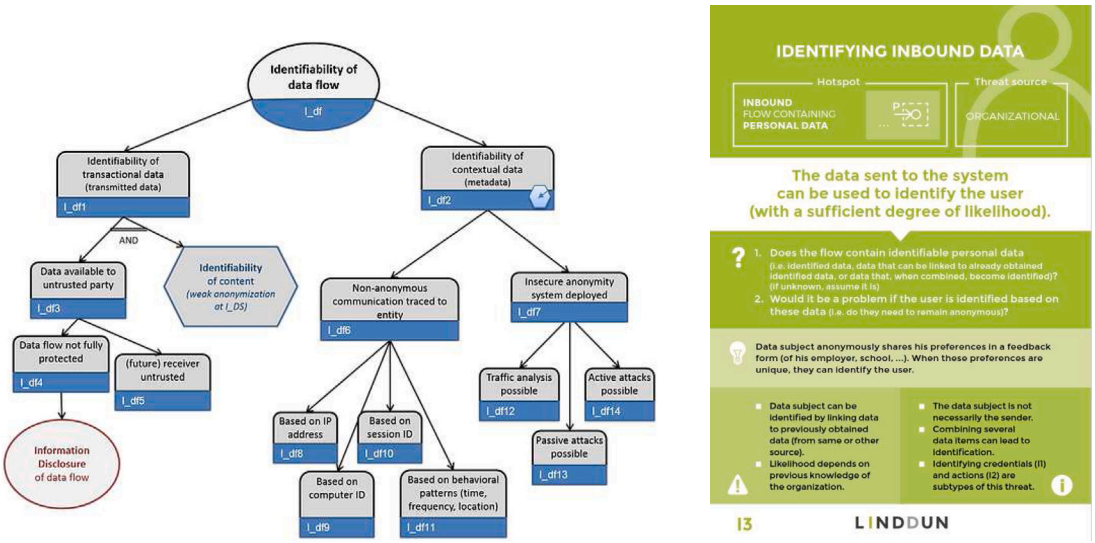
Based on the above, we argue that the current encoding of privacy threat knowledge fundamentally lacks in robustness and adaptability, and we motivate the overall need along two dimensions: (1) independently evolving and updating the privacy threat knowledge and examples; and (2) supporting different analysis approaches or methods. The remainder of this section discusses these different dimensions in further detail.

2.1. Robustness to change: refining knowledge bases to co-evolve with a changing privacy threat landscape

Over the years, there have been several iterations on and improvements to the LINDDUN threat knowledge (Deng et al., 2011) such as updated privacy threat trees (Wuyts, 2015), a refinement for interaction-based threat elicitation (Sion et al., 2018), hotspot-based threat cards (Wuyts et al., 2020).

However, the existing privacy threat knowledge encoding is inflexible as it is created separately for every different type of output (for example, privacy threat trees vs. threat cards) or methodological variant. This inhibits effectively maintaining the privacy threat knowledge over time, for example to incorporate newly-emerging threat types in the knowledge base (e.g., membership inference threats specific to machine learning approaches (Shokri et al., 2017; Hu et al., 2022b) that refer to the situation in which a trained classifier may leak information that a certain individual was part of the training set). Furthermore, the privacy threat knowledge encoded in these different artifacts is not guaranteed to be consistent or equally up to date as these are all separately constructed and maintained threat knowledge resources.

Another disadvantage of the existing representation is that several subtrees enumerate the lack of specific solutions, such as not capturing the core privacy problem at hand. For example, in Fig. 1(a), the node '*Data flow not fully protected*' indicates an insufficient level of protection as a precondition to an identity leakage problem, but further fails to articulate the specific issue at hand. This hinders overall maintainability, as the set of potential solutions to prevent the main threat type would have to be continuously updated to keep track of more recent solutions. Therefore, we argue that the elements in the tree should focus



(a) Example LINDDUN threat tree ('*Identifiability of data flow*') (Wuyts et al., 2014)

(b) Example LINDDUN GO threat card ('*Identifying inbound data*') (Wuyts et al., 2020)

Fig. 1. Illustration of current threat knowledge representations in LINDDUN.

on characteristics of the problem that trigger the possibility for the threat, rather than the presence or absence of solutions to prevent it.

A clearer delineation between problem space and solution space will lead to a more maintainable threat knowledge base, that can evolve independently of actual solutions such as privacy-enhancing technologies (PETS).

2.2. Reusability and applicability to different analysis approaches

The current LINDDUN privacy threat trees exclusively focus on a DFD-centric per-element threat elicitation process (Wuyts, 2015). For example, Fig. 1(a) illustrates the previous identifiability tree which immediately focuses on the data flow DFD element type at the root of the tree. Over time, numerous other, more extensive, elicitation approaches emerged such as interaction-based (Sion et al., 2018) or pattern-based (Sion et al., 2019a; Tuma et al., 2020). Approaches such as LINDDUN GO (Wuyts et al., 2020) do not even rely on a DFD, and thus cannot leverage the pre-existing privacy threat trees.

Therefore, it is a key requirement for novel privacy threat knowledge representations to not be tied to one particular elicitation methodology. This does not preclude those representations from providing guidance or support for a particular elicitation method. Instead, they should be flexible so that support can be added for different elicitation methods. Indeed, by providing an extensible mechanism to include such information, various other types of privacy threat knowledge outputs can be derived from it.

Decoupling the privacy threat knowledge from its representation artifacts (PDF, website, interactive catalog, threat trees, threat cards, etc.) is required as different approaches rely upon different artifact types. Finally, the support within different threat modeling tools (Microsoft Threat Modeling Tool (Microsoft Corporation, 2016, 2020), SPARTA (Sion et al., 2018a), Pytm (Tarandach, 2023), Threagile (Schneider, 2023), OWASP Threat Dragon (OWASP, 2025), etc.) can be provided and maintained from the same knowledge structure. This requires support for automatically processing the threat knowledge to enable the derivation to those different artifact types and outputs.

3. Approach

The approach taken in this work is essentially one of case-based, incremental and iterative, expert-driven co-design. This leads to two complementary and co-dependent processes: construction of the modeling support for threat knowledge in general (i.e. supporting both security and privacy threat knowledge) and validation through creation of the new LINDDUN privacy threat knowledge. These two efforts are mutually reinforcing. The effort to systematize the new LINDDUN privacy knowledge has in turn improved the tools and methods to manage, version, and evolve threat knowledge and to extract it in formats accessible to diverse stakeholders for multiple threat modeling approaches. These interactions are illustrated in the graphical overview of the approach (Fig. 2) and the two complementary dimensions are further explained below.

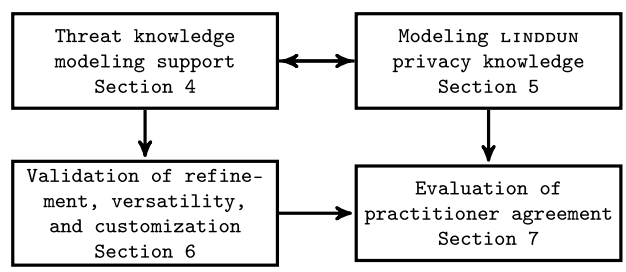


Fig. 2. Graphical overview of the approach.

1. The establishment of the underpinning model-driven approach, the metamodel and modeling support for capturing threat knowledge, and the design and implementation of the tools and infrastructure. This leads to the threat knowledge metamodel (Section 4), and tools to model, manage, extract, and export threat knowledge to diverse human- and machine-readable formats. Additionally, the integration of these tools in CI/CD frameworks has been accomplished to support gradual and continuous evolution, customization and to meet the requirements discussed in Section 2. The validation of the tooling and infrastructure to support these flexibility dimensions is explained in Section 6.
2. The second component entails the application of the aforementioned approach and modeling support to capture and extend the LINDDUN privacy threat knowledge. This activity involves an iterative process to create and validate the privacy threat knowledge structures (privacy threat trees) through expert workshops, driven by examples collected from case studies, validation cases,

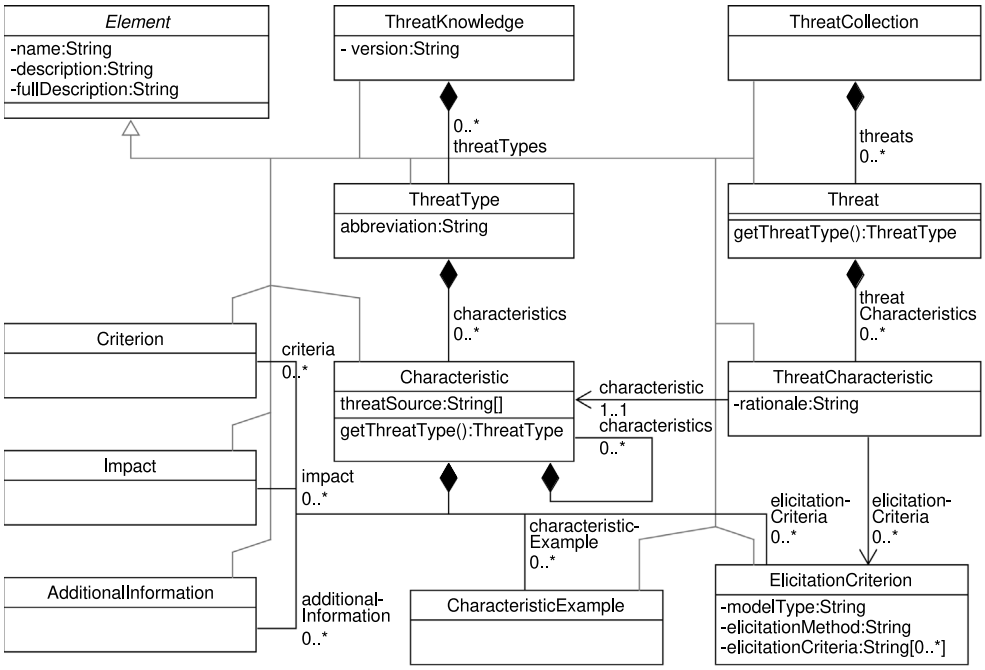


Fig. 3. Threat knowledge metamodel class diagram.
The figure contains the classes for expressing the threat knowledge, types, characteristics, etc. The top three classes on the right-hand side of the figure are the concepts for expressing concrete threats using the generic threat knowledge expressed with the other elements. All classes inherit from the Element class for shared properties such as the name and description.

and diverse academic publications in the privacy domain (Roe, 2010; Pfitzmann and Hansen, 2010; Common Criteria, 2012; Solove, 2005; ULD, 2017; Hoepman, 2014; Deng et al., 2011; Wuyts, 2015; Hartzog, 2018; Spiekermann and Cranor, 2009; Sweeney, 2000; NIST, 2020; Westin, 1967; Lederer et al., 2004; Patil and Kobsa, 2009; Funk, 2020; Brooks et al., 2017). The primary outcome is the new LINDDUN privacy threat knowledge model. This threat knowledge is (in the form of the threat trees as described in Section 6) evaluated by assessing the practitioner agreement as elaborated upon in Section 7.

4. Threat knowledge metamodel

As discussed previously, it is a key goal to establish a more principled and structured model-driven approach to capture and manage threat knowledge. This section introduces the '*threat knowledge metamodel*', a fundamental way to structure and express privacy and security threat knowledge in a knowledge base. This metamodel provides support for unambiguously capturing the threat knowledge in a structured format for reuse in multiple scenarios in line with the flexibility dimensions (outlined in Section 2). The metamodel is deliberately kept generic enough to capture other threat knowledge (e.g., security) and is validated in Section 5 by leveraging it for constructing and expressing the new LINDDUN privacy threat knowledge.

Fig. 3 depicts the complete metamodel for encoding threat knowledge in a UML class diagram. All classes inherit from the *Element* class to capture common properties that are shared by all classes. The presentation of the other threat knowledge metamodel classes is split into three parts: (i) support for expressing generic threat knowledge (type-level), (ii) modeling concrete example threats (instance-level), and (iiii) a concrete example to illustrate both these concepts. We further elaborate on these in the subsequent three sections.

4.1. Expressing generic threat type knowledge

ThreatKnowledge The *ThreatKnowledge* class represents a logical collection or aggregated grouping of distinct threat types (for example, the LINDDUN, STRIDE, or any other types). This concept provides an identity to the complete collection of threat types and their characteristics to enable the construction of different *ThreatKnowledge* collections for other variants or versions.

ThreatType The *ThreatKnowledge* collection contains the actual *ThreatType* elements such as, for example, *Linking* in LINDDUN or *Spoofing* in STRIDE. These are the root elements used to make a high-level distinction between threat types to scope the analysis and provide a coherent breakdown into their characteristics.

Characteristic The *Characteristic* class expresses the key characteristics of a particular threat type. A characteristic can be broken down into sub-characteristics to enable a more fine-grained breakdown. This breakdown into sub-characteristics makes them more specific. For example, for identifying threats the pseudonym characteristic can be broken down into identifier or quasi-identifier, as each of those can serve as a pseudonym to lead to identification. For tampering threats, corrupting a process can be split up into crafting malicious inputs or tampering with the memory of the process.

The characteristics focus on the key properties (i.e. characteristics) of what entails a particular threat, rather than focusing on particular technical criteria such as the absence of a certain technical countermeasure. This fundamental change from the previous threat trees provides a new way to reason about and construct different threats by combining multiple characteristics in the tree thereby avoiding ambiguity and complexity in how that could be encoded through inheritance or combinations of AND and OR criteria over different leaves or branches in the tree. The characteristic breakdown of a threat type in this model only uses OR, allowing the combination of any number of characteristics to express complex threats.

These modeling concepts are sufficient to capture existing threat trees. However, to further expand what can be expressed, the *Characteristics* are extended with additional properties such as *CharacteristicExamples* and *Criteria*. Typically, this information is encoded at the level of the

final (i.e. the tree leaf) characteristics, but this is not required. Common shared properties can also be linked to the parent characteristics to prevent duplicating that information in the threat knowledge structure.

CharacteristicExample *CharacteristicExamples* express a concrete example of a threat exhibiting that characteristic. Such an example illustrates the issue by making it very concrete to aid users in understanding and interpreting that particular characteristic.

Criterion The *Criterion* expresses textual questions for a threat modeler to assess the relevance of a particular characteristic. This attribute helps users to determine whether a particular characteristic would apply for the concrete application and context being assessed. The criterion element focuses on human end-users.

ElicitationCriteria The *ElicitationCriterion* expresses the criteria that can be evaluated to assess whether or not the characteristic applies. These can be used to support threat elicitation and thus focus on tools to interpret and use this information. It supports different types of elicitation methods that may rely on different types of model representations (e.g., a DFD). This is necessary to provide more generic support to prevent limiting the threat knowledge to one particular elicitation method (e.g., element-based, interaction-based, or pattern-based elicitation). For example, the criterion can be specified for interaction-based elicitation on a DFD or for a completely different type of diagram (e.g., sequence diagram). By encoding these separately, the same threat knowledge encoded in the characteristics can be restructured and filtered for different threat modeling approaches.

Impact The *Impact* element provides an explanation about the impact of the threats with that characteristic. This can be useful when a threat modeler also wants to record information about the risk or the priority of the elicited threats.

AdditionalInformation The *AdditionalInformation* object can be used to include any other type of relevant information under a characteristic.

4.2. Expressing concrete threats

The next set of concepts are used for expressing threats (of varying degrees of concreteness) using the existing threat knowledge concepts (encoded as threat types and threat characteristics). A key difference with the concepts above is that the threats expressed here are concrete instances, while the elements above are used to express the types.

ThreatCollection The *ThreatCollection* represents a logical collection or aggregated grouping of distinct threats (i.e. instances, not types). This concept provides an identity to the complete collection of threats to enable constructing different sets of concrete threats such as the results of analyzing a particular case.

Threat The *Threat* is used to express a concrete threat. A threat relates one or more characteristics. Typically, complex threats in real-world systems will exhibit a combination of different characteristics.

ThreatCharacteristic The *ThreatCharacteristic* is used to point to the concrete *Characteristic*. It can be augmented with some additional rationale in its description or elicitation criteria to express how the specified characteristic applies.

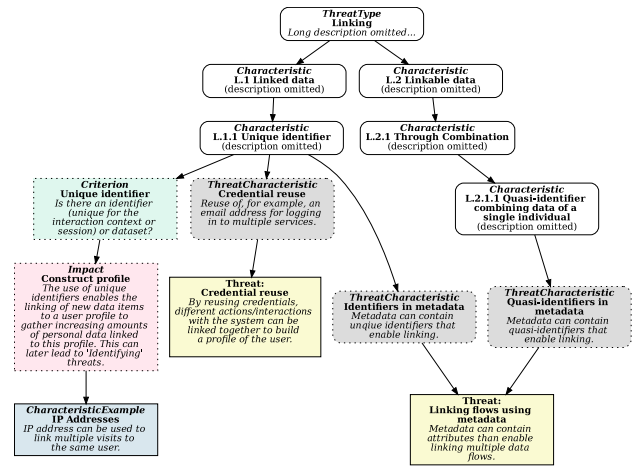


Fig. 4. Partial example of Linking tree illustration with concrete threat instances. This tree depicts a part of the tree for the Linking *ThreatType* (full tree in Fig. 6). The top of the figure shows how the *ThreatType* is decomposed into a number of *Characteristics*. The first *Characteristic L.1.1* contains a *Criterion*, *Impact*, and *CharacteristicExample* element. The yellow solid rectangles depict two concrete *Threat*s, which refer to their relevant *Characteristics* using the *ThreatCharacteristics* that describe how the generic *Characteristic* is applicable to the concrete *Threat*.

4.3. Example linking privacy threat type

The use of the threat knowledge metamodel for encoding threat knowledge is illustrated with a concrete example for the *Linking* privacy threat. Fig. 4 illustrates this by visualizing (a part of) the breakdown of the *Linking* threat type into its characteristics. The top of Fig. 4 illustrates the threat type (i.e. Linking) followed by some of its characteristics that provide a more detailed breakdown (the example only includes two of them for illustrative purposes).

Below the *L.1.1 Unique identifier* leaf characteristic, the criteria, impact, and examples are visualized. Fig. 4 visualizes one example for the *L.1.1 Unique identifier* leaf characteristic.

In addition to the small examples that focus one particular leaf characteristic, it is possible to express more complex examples that combine one or more characteristics. The two *Threat* instances at the bottom illustrate this mechanism. These threats have a *ThreatCharacteristic* object that points to the *L.1.1* and *L.2.1.1 Characteristic*s to include the motivation or description of how those characteristics are applied in the context of the example *Threat*.

5. Modeling the LINDDUN threat knowledge

The generic modeling support for capturing threat knowledge, as elaborated in the previous section, is validated through the modeling of the LINDDUN threat knowledge and applying it to a number of validation cases. This section explains the iterative process that was followed to model the new and expanded LINDDUN threat knowledge and apply it to the cases. Fig. 5 provides a graphical depiction of the approach that was followed. Each iteration is explained in a separate section.

5.1. Initialization of main structures

The first step consists of the initial encoding of the LINDDUN privacy threat knowledge using the presented concepts (from Section 4). The following three key decisions were made when creating the initial version.

Subdivision into LINDDUN threat types. This is an initial constraint to retain the already established seven LINDDUN threat types (Linking, Identifying, Non-repudiation, Detecting, Data Disclosure, Unawareness & Unintervenability, and Non-compliance).

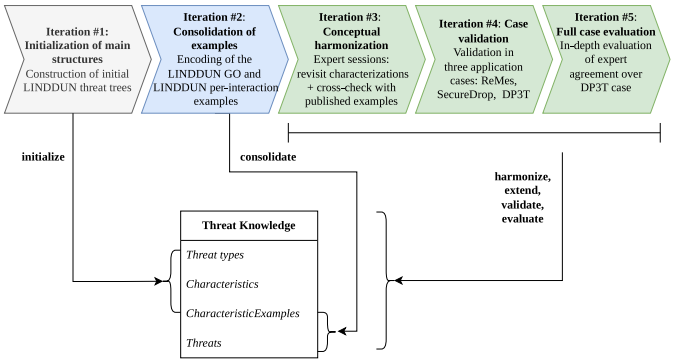


Fig. 5. A step-by-step breakdown of the activities performed to extend and improve the LINDDUN privacy threat trees.

Breakdown into characteristics. The breakdown of threat types into their characteristics is intended to avoid the earlier logic conditions over branches. Furthermore, it no longer requires the need to include additional criteria or conditions that refer to the absence of countermeasures. Instead, the breakdown focuses on characteristics inherent to the threat type.

Data Disclosure as a first-class threat type. For *information disclosure*, the previous version of LINDDUN referred to the STRIDE security threat type. The new version explicitly includes *Data Disclosure* as a first-class threat type with a broader coverage than the earlier security threat type.

With the aforementioned decisions and constraints in mind, the initial LINDDUN threat knowledge structure is created and populated. The creation of the initial version is driven by a top-down breakdown, starting from the LINDDUN threat types. Every LINDDUN threat type is decomposed and refined into its component characteristics. This breakdown is driven by the characterizations of privacy threats in the literature (Roe, 2010; Pfitzmann and Hansen, 2010; Common Criteria, 2012; Solove, 2005; ULD, 2017; Hoepman, 2014; Deng et al., 2011; Wuyts, 2015; Hartzog, 2018; Spiekermann and Cranor, 2009; Sweeney, 2000; NIST, 2020; Westin, 1967; Lederer et al., 2004; Patil and Kobsa, 2009; Funk, 2020; Brooks et al., 2017; Wuyts et al., 2020; Sion et al., 2018). The breakdown does not start with a re-encoding of the previous threat trees (Wuyts, 2015; Deng et al., 2011), these resources are combined with the other literature. Afterwards, the existing threat trees (and their examples) are used again in the consolidation and validation step in Section 5.2.

5.2. Consolidation of examples

The first validation step involves verifying that the previous LINDDUN trees can be fully expressed in the new trees. Every leaf in the previous tree is checked, including logic conditions and references to other threat types.

There are two possibilities regarding the coverage. Either the coverage is straightforward because there is a corresponding characteristic in the new threat, or the leaf is covered by definition because of the change in the meaning or interpretation of the threat types or characteristics. For example, some trees had an explicit reference to the *Information disclosure* security threat, however the new trees consider both internal and external adversaries and, as such, do no longer require such an explicit *Information disclosure* threat as a precondition. Any elements that are not covered are addressed either through extending characteristics or expanding or clarifying their descriptions.

The next validation step entails verifying that existing threat knowledge can be readily expressed using the new threat trees. This validation exercise consists three parts: expressing existing privacy threat examples that were previously collected, expressing the LINDDUN GO privacy threat cards (Wuyts et al., 2020), expressing the interaction-based LINDDUN threat examples (Sion et al., 2018c) for every type of interaction.

Table 1
Application cases.

Case	Topic	Model size					Pairs[f]
		P[a]	DS[b]	EE[c]	DF[d]	TB[e]	
DP3T	Contact-tracing	2	2	3	22	2	292
SecureDrop	Whistleblower submission system	17	7	7	47	8	618
ReMeS	Remote sensing and measuring	8	2	3	32	0	424

[a] Processes
[b] Data stores
[c] External entities
[d] Data flows
[e] Trust boundaries
[f] Pairs denote all combinations of ThreatType and Interaction that would need to be assessed during an interaction-based threat elicitation analysis.

Modeling existing threat examples. This step entails modeling a wide range of privacy threat examples that were collected over time as they were published when new incidents were uncovered in different software products and online services. Each of these examples are captured using the characteristics in the threat trees to ensure they are adequate to represent these threats.

Modeling LINDDUN GO. This validation step involves modeling all the existing LINDDUN GO (Wuyts et al., 2020) threat cards using the nodes of the proposed threat trees. This step ensures that the new LINDDUN threat trees provide sufficient coverage to uncover all the threats that can also be elicited using the LINDDUN GO cards.

Modeling the interaction-based LINDDUN *example threats.* This validation step involves modeling all the example threats for the interaction-based LINDDUN threat elicitation (Sion et al., 2018). Encoding all these examples provide evidence that the LINDDUN threat trees are able to express these types of threats.

5.3. Conceptual harmonization

The third iteration entails conceptual harmonization. In this phase, three privacy threat modeling experts iterate over each of the LINDDUN privacy threat trees during several in-depth sessions. In each session the detailed breakdown into characteristics is discussed, the meaning and interpretation is fine-tuned, and the elements are cross-checked with privacy threats. This ensures overall consistency in the interpretation and meaning, accuracy of the description, and verifies the characterizations are suitable to express the privacy threats.

5.4. Case validation

With the initial candidate of the LINDDUN privacy threat knowledge ready, a more extensive validation is performed by applying the LINDDUN threat trees with interaction-based LINDDUN. This validation is applied on three different cases: a Bluetooth contact-tracing application (DP3T), a whistleblower submission system (SecureDrop), and a remote measuring, monitoring, and control system (ReMeS). Table 1 provides an overview of these cases and indicates the size of the models.

Generating threat candidates. To reduce the bias of the threat modelers' execution of the interaction-based elicitation, all the ThreatType–Interaction pairs are systematically generated up-front. This results in a list of all the pairs (i.e. a combination of a threat type and a DFD interaction) that need to be assessed. The threat modelers go over these candidates to determine whether there is a concrete threat of that type that can be instantiated.

Sampling the threat candidates. Automatically generating all candidates leads to a considerable number of threats. For example, the SecureDrop case has a threat count of 618 threat candidates, each of these candidates would have to be evaluated with the threat trees to generate concrete threat instances. To keep the size of the manual validation manageable, we sample on threat candidate for every type of interaction (i.e. every valid combination of element types: *Process-DataFlow-DataStore*, *Process-DataFlow-ExternalEntity*, etc.). This leads to a total set of 66 candidates for every case, as this is the total number of valid InteractionType—ThreatType combinations that are possible. To determine the set to manually assess, a candidate is picked at random for every combination that has to be tested.

Data provided to validators. To support the validation by threat modelers, a similar set of information is provided for every application case that is analyzed. The following set of information is provided to the validators.

instructions.pdf File providing the instructions for applying the LINDDUN threat trees.

trees.pdf The PDF file containing the threat trees for the LINDDUN threat types. All the nodes and leaves are numbered and for each leaf, one or more examples are provided.

description.pdf For every case, this file provides a standalone and detailed description of the application case. This includes (i) a high-level description of the application and the main elements of the system, (ii) the Data Flow Diagram (DFD) (DeMarco, 1979) of the application, (iii) additional information on the considered attacker models in the design of the application (where available), and (iv) references to supporting materials and sources.

toAssess.csv A template file providing the list of interactions in the DFD to consider for eliciting LINDDUN privacy threats. These interactions are automatically generated using interaction-based LINDDUN (Sion et al., 2018), so they can focus exclusively on constructing the threats without having to determine whether the LINDDUN threat type is actually applicable in a specific context.

After the validation efforts as described above, a structured workshop session is held with three experts to discuss the results and resolve any encountered issues with the privacy threat knowledge base such as minor issues (for example, rephrasing characteristic descriptions) or more major issues (for example, refactor characteristic nodes, to address incompatibilities).

5.5. Full case evaluation

The final validation step entails the application on a full application case. Three privacy threat modelers apply the final version of the LINDDUN privacy threat trees on the complete set of threat candidates to elicit privacy threats. For the full assessment, the DP3T application was selected. The complete list of candidates (interaction + threat type) was subdivided into three sets, each of which covering 2/3 of the threats. This ensures that every candidate is evaluated by two threat modelers.

After the validation on the full application, a final discussion with the three threat modeling experts addresses any potential issues or ambiguities and threat characteristics and their descriptions. This led to the final version of the threat trees outlined in the next section.

5.6. Trees

The result of the approach depicted in Fig. 2 and elaborated upon in Sections 5.1 to 5.5 leads to the resulting set of LINDDUN threat trees.

Fig. 6 visualizes the resulting *Linking* threat tree with the threat type at the root and a decomposition into characteristics. Each characteristic contains a name and a short description.

The resulting threat knowledge base with the seven LINDDUN threat types contains with 65 characteristics, 128 characteristic examples, 72 criteria, 52 impact descriptions, 49 additional information descriptions, 43 elicitation criteria. Elements such as the elicitationCriteria will further be extended over time as support for other elicitation methods is included in the knowledge base in the future.

The full set of all the LINDDUN threat trees, the LINDDUN source files, and the tool to generate the different variants of the trees (with examples, impact descriptions, etc.) are all publicly available on the LINDDUN website (DistriNet, KU Leuven, 2025).

6. Validation

We present three validation efforts, each tailored to showcase the degree to which the three motivation dimensions (outlined in Section 2) on (i) extension and refinement, (ii) versatility, and (iii) customization are addressed.

6.1. Extension and refinement of privacy threat knowledge

Privacy threat knowledge domain is not a static resource. Existing repositories for security knowledge on concrete vulnerabilities and incidents illustrate the need for updating and maintaining these resources over time. This requires knowledge representations to be flexible and extensible to support the extension and inclusion of new threat knowledge information and new attach techniques as new types of flaws are discovered that cannot be accurately represented with the existing knowledge. There is thus a need to extend and refine the knowledge in a number of ways: (1) expanding the threat characteristics for new types not accurately covered by existing ones, (2) expanding in depth to provide a more detailed breakdown of existing characteristics, and (3) extending the knowledge base with new and better examples.

The metamodel presented in Section 3 supports capturing all the aforementioned types of information. The model supports extending the knowledge on threat characteristics both in breadth (1) by expanding with new types and in depth (2) by providing more detailed breakdowns. Furthermore, the metamodel supports expressing threat examples at multiple levels of detail to allow the inclusion of concrete threat examples at the most appropriate level. The examples per characteristic can continue to be expanded over time with more examples. All of those support extension and refinement of the threat knowledge over time.

The modeling support for the LINDDUN privacy threat knowledge is created in an eclipse-based application: *Threat Knowledge Modeler* (TKM). The presented metamodel from Section 4 is implemented in the Eclipse Modeling Framework (Steinberg et al., 2008). This TKM application is used to model the entire LINDDUN privacy threat knowledge base.

These modeling results are captured in multiple artifacts (Fig. 7 illustrates how they can be used):

linddun.threatknowledge The main LINDDUN threat knowledge model that encodes the LINDDUN threat types and their characteristics. This main model is complemented by additional threat knowledge files that refer to the main model but add additional more complex examples and concrete threats.

linddungo.threatknowledge The LINDDUN GO threat knowledge file is one such example. It is a threat collection that contains more concrete threat examples that refer to the characteristics of the main LINDDUN threat knowledge model.

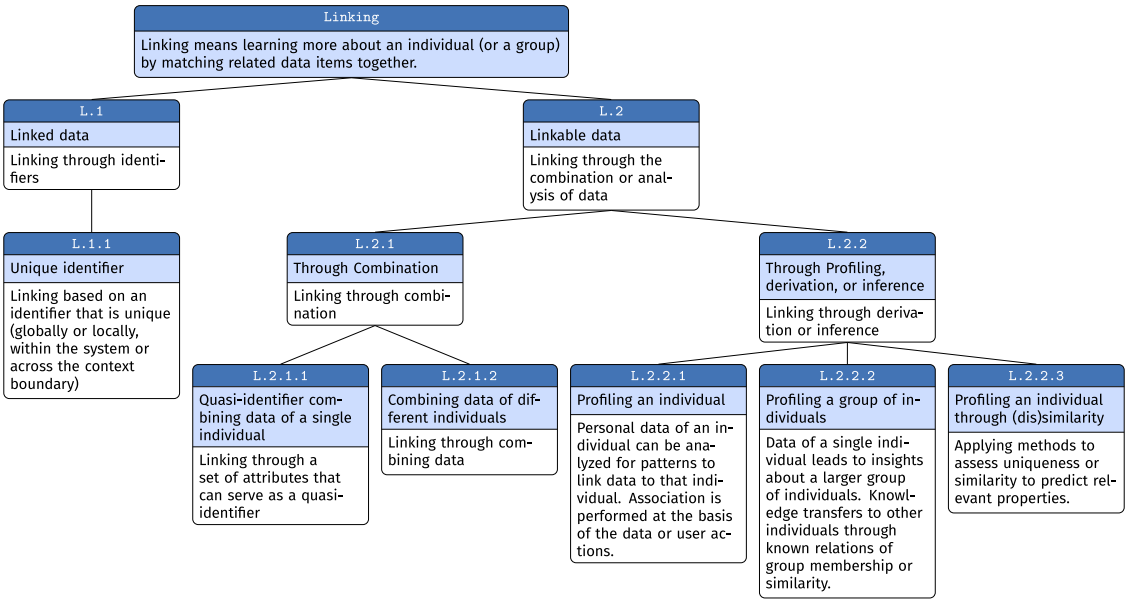


Fig. 6. Linking threat tree.
This figure visualizes the *Linking* threat type decomposed into its characteristics together with their descriptions. There are other variants of this tree available that include additional information such concrete examples and criteria per leaf characteristic.

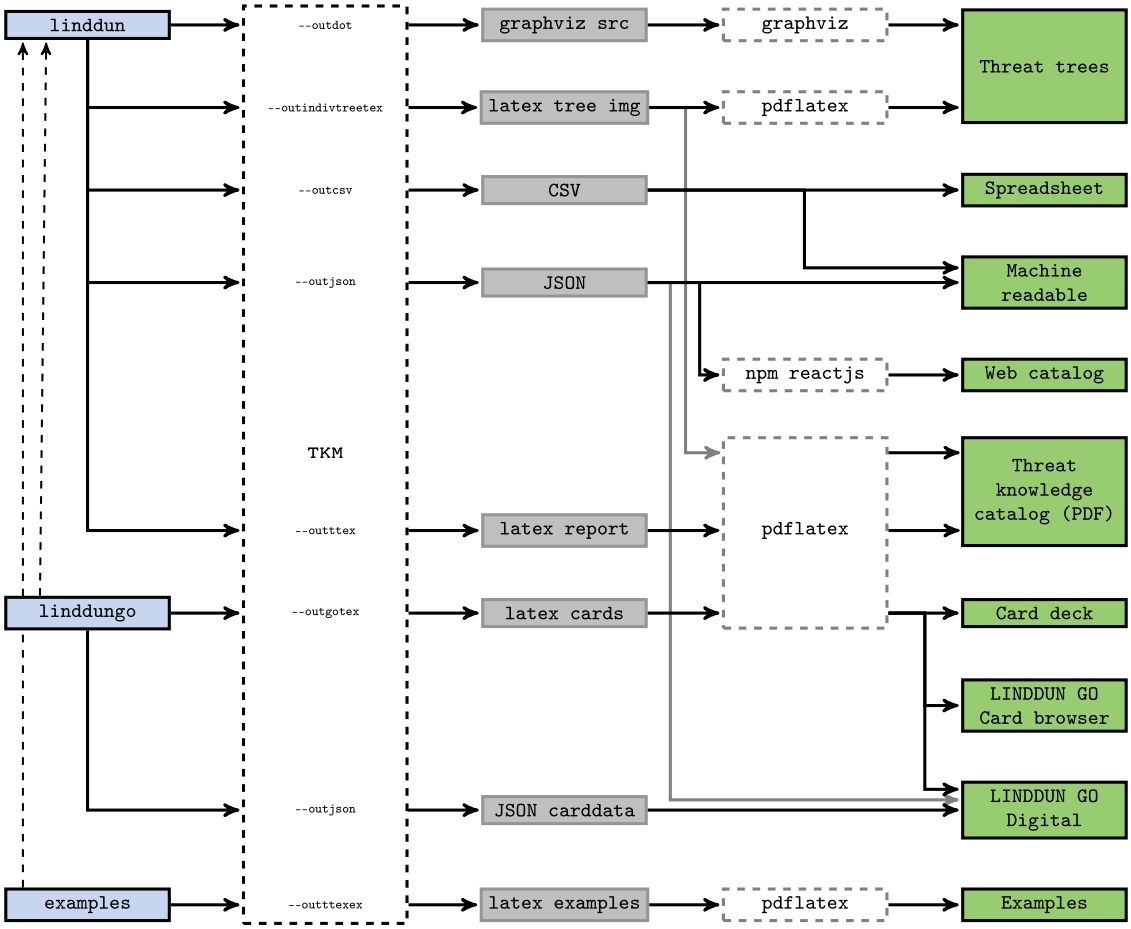


Fig. 7. Schematic depiction of threat knowledge processing workflow to generate the artifacts.
This diagram shows the main LINDDUN threat knowledge resources that serve as the input for the automated derivation of a wide range of threat knowledge artifacts to enable the reuse of the LINDDUN in a wide range of approaches. The filled rectangles representing input, temporary, and output files. Dashed rectangles represent the tools used for processing those files and generating the outputs. The left-hand side shows the three main input files, and shows the dependency from linddungo and the examples files to the main linddun threat knowledge. Table 2 shows the mapping of these automatically generated artifacts to the different approaches.

Table 2
Overview of potential approaches and artifacts
This table provides an overview of the automatically derived artifacts and how they can be used in various contexts. These usages go beyond elicitation approaches, and also illustrates the use of various export formats to enable the integration in tooling or the construction of custom representations.

Approach	Threat trees	Spreadsheet	Machine readable	Web catalog	Threat knowledge catalog	Card deck	LINDDUN GO card browser	LINDDUN GO digital	Examples
	6.2.1	6.2.2	6.2.3	6.2.4	6.2.5	6.2.6	6.2.7	6.2.8	6.2.9
Manual/ad-hoc	x			x	x	x	x	x	x
Hotspot-driven/card-based						x	x	x	x
Per-element	x		x	x	x				x
Per-interaction	x		x	x	x				x
Tool-integrations	x	x	x	x					
Custom representations		x	x						

examples.threatknowledge A collection of more complex privacy threat examples that combine multiple LINDDUN threat characteristics.

The structured representation also provides benefits in modeling and structuring the threat knowledge as it forces the systematic consideration and breakdown of threat types into detailed threat characteristics. This modeling exercise helps to improve the quality of the characterization, improving the semantics by systematically breaking down threat types into their subcomponents.

Beyond the modeling support to express the knowledge, the actual encoding and storage of this knowledge also improves the flexibility for this dimension. The threat knowledge models are versioned and stored in a repository to trigger automated tooling to generate different representations of this knowledge in a variety of formats for further use in different threat modeling approaches. Both the TKM tool and the aforementioned artifacts that capture the LINDDUN threat knowledge are available on the LINDDUN website (DistriNet, KU Leuven, 2025).

Section 6.2 goes into more detail on the tooling and the support for extracting the knowledge to a range of different output formats.

6.2. Versatility and reuse across different approaches

There are different threat modeling approaches ranging from ad-hoc analyses (e.g., brainstorming sessions) to more comprehensive systematic analyses (as elaborated upon in Section 2.2). These different types of approaches ideally leverage the same threat knowledge but require widely differing types of resources in practice as, for example, a threat modeling card deck is quite a different type of artifact compared to a structured machine-readable representation that is used automated threat modeling tools. However, regardless of the concrete approach a particular user may opt for in practice, the selected threat knowledge artifacts should contain the most relevant and up-to-date threat knowledge information. Fig. 7 provides an overview of how these artifacts are derived.

A key design goal of the TKM support is to enable such use cases from the start by centrally encoding the relevant threat knowledge in a single model and programmatically navigating this model to extract the necessary information for building a range of different artifacts. The previous section elaborated on the modeling support for capturing this knowledge. This section dives further into how this representation can be used to support artifact generation. To validate the support in the presented TKM tooling, we implemented a range of extractors to illustrate the breadth and diversity of artifact types that can be extracted from the TKM model. Fig. 7 provides schematic depiction to illustrate this diversity. The generated artifacts enable the use of the LINDDUN privacy threat knowledge in a range of different approaches but also their integration into tooling. Table 2 provides an overview of the uses of these artifacts in different contexts.

All the currently supported artifact are explained in more detail below together with concrete illustrations, after which the full toolchain for automated generation of all the artifacts is presented in Section 6.2.10.

6.2.1. Threat trees

The threat trees are the most straightforward artifact to generate from the threat knowledge as they analogously capture an increasing level of detail while navigating downward in the tree. Building this tree structure from the knowledge requires iterating over every threat type, and building a tree structure using the nested characteristics. As mentioned before, these trees differ from earlier versions because of the subdivision into characteristics that can be combined. Finally, the leaves of the tree export are extended with concrete examples, impact descriptions and additional information elements. This extraction logic is fully configurable to generate different variants of the trees where such properties can be included or excluded as desired. The export has been implemented both graphviz source files and in latex source files from which PDFS, PNGS or other formats can be constructed. This way a range of different users, with different needs in terms of explanation and examples, can be supported. Fig. 8(a) visualizes the part of the *Linking* tree with examples and criteria.

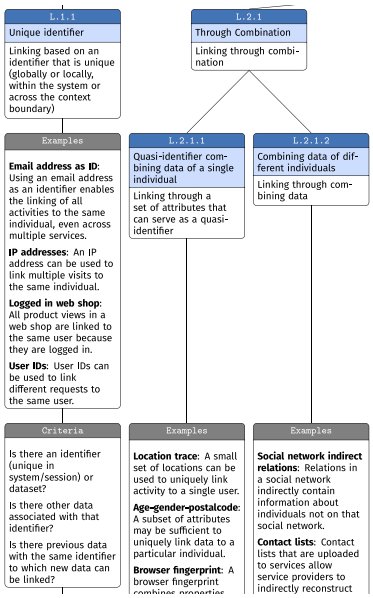
6.2.2. Spreadsheet

In additional to textual and graphical exports, the threat knowledge can also be exported in CSV format. Fig. 8(b) shows a fragment of the CSV export. This format contains a description of all the characteristics and short descriptions and examples. It enables easy integration in custom workflows for users that already use spreadsheets to keeping track of elicited threats and can integrate and refer to the relevant LINDDUN characteristics.

6.2.3. Machine readable formats

The structured formats enable the threat knowledge to be leveraged other automated tools or allow end-users to further process or build on top of the privacy threat knowledge. There are currently two main formats implemented in the TKM tooling: JSON and the aforementioned CSV support. The CSV support is geared mainly towards end users that wish to use the full list of threat characteristics to further process and use in their custom approaches. The JSON format provides the full detail of the entire LINDDUN threat knowledge structure. I.e. it is a transformation of the internal XML-based representation used in the TKM tool into a more accessible format for use on the web. Because of this, it is also used as an intermediary step (or additional supporting data) in other output formats such as (1) the web catalog, which uses it to retrieve all the data on characteristics and examples; and (2) LINDDUN GO digital, which uses it show additional examples when a user clicks the example list on a specific card. Fig. 8(c) visualizes a part of the JSON export for the *Linking* threat type.

While the current set of machine-readable formats is limited to CSV and JSON to illustrate a number of integrations and reuse in different tools, the collection of formats can be further extended in the future to support a wider range of applications and integrations. For example, the transformation to OWL ontology can support integrations with other privacy ontologies (Pandit et al., 2019, 2025; Gharib et al., 2021) in the future.



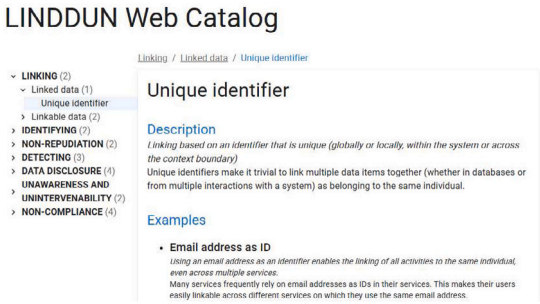
(a) Linking Threat Tree with examples and criteria

```
ID,Type,Title,Description,Examples,Questions,Impact
L.1,Linking,Linked data,Linking through identifiers,,,
L.1.1,Linking,Unique identifier,"Linking based...",
    "Using an email ...",Is there...,"Unique..."
L.2,Linking,Linkable data,Linking through the combination
    or analysis of data,,,
```

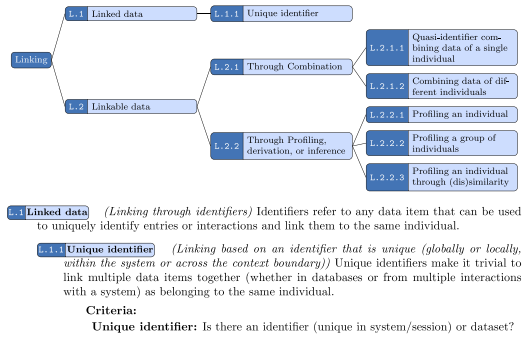
(b) Overview of a CSV export of the characteristics

```
"id" : "L.1",
"fullDescription" : "Identifiers refer to any...",
"refs" : [ ],
"characteristicExample" : [ ],
"elicitationCriteria" : [ ],
"impact" : [ ],
"criteria" : [ ],
"threatSource" : [ ],
"additionalInformation" : [ ],
"name" : "Linked data",
"description" : "Linking through identifiers",
"children" : [ {
    "id" : "L.1.1",
    "fullDescription" : "Unique identifiers ...",
    "refs" : [ ],
    "characteristicExample" : [ {
    "name" : "Email address as ID",
    "description" : "Using an email address...",
    "refs" : [ ],
```

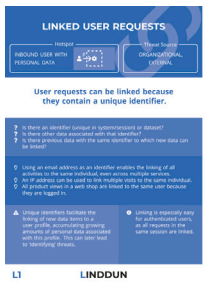
(c) Overview of a JSON export of the characteristics



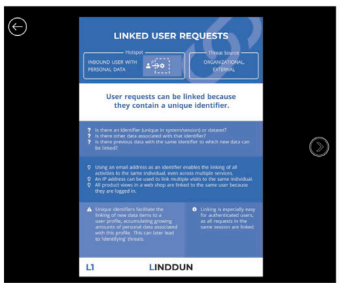
(d) Linking in Web Catalog



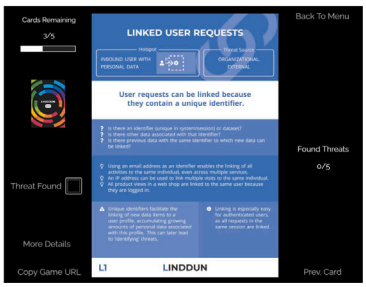
(e) Linking in PDF Catalog



(f) LINDDUN GO export example



(g) LINDDUN GO card browser example



(h) LINDDUN GO digital example

Fig. 8. Overview of the LINDDUN exports.
Example exports are shown for the threat trees, the CSV format, the JSON format, the interactive web catalog, the PDF report catalog, LINDDUN GO, the LINDDUN GO card browser, and the LINDDUN GO digital version.

6.2.4. Web catalog

The web catalog provides an interactive website to browse the threat trees and navigate different characteristics and examples. It is built as a reactjs application which leverages the JSON encoded version of the threat knowledge. Fig. 8(d) visualizes the web catalog for a *Linking* characteristic.

6.2.5. Threat knowledge catalog

The threat knowledge catalog provides a full export of all the information contained in the threat knowledge base. Fig. 8(e) Visualizes a part of the PDF report for the first *Linking* characteristics. A high-level view of every tree is provided, followed by a detailed description of all the information contained in the model. This involves a detailed explanation of every characteristic and subcharacteristics, as well as all the relevant examples, criteria, impact descriptions, and any additional information.

6.2.6. LINDDUN GO card deck

The previous version of LINDDUN GO (Wuyts et al., 2020) was constructed in parallel from the original LINDDUN threat trees and thus separately encodes (some of) this knowledge in a different format. These resources are thus maintained completely separately from one another. By encoding the privacy threat knowledge as outlined above,

LINDDUN GO cards can be exported from the same knowledge base similar to the threat trees.

The constructed prototype automatically creates a LINDDUN GO card deck starting from a threat knowledge set, to automatically retrieve the relevant knowledge to populate the different cards. Fig. 8(f) shows a single card from which all the information is derived from the threat knowledge structure. A single card is populated as follows. The title and description are extracted from a *Threat* instance in the knowledge base. All the questions, examples, impact description, additional information, hotspot selection, and threat source are extracted from the relevant *characteristics* the *threat* instance points to (through the *ThreatCharacteristics*). These elements are further filtered to ensure that the elicitation criteria mentioned in the threat characteristic correspond with the elicitation criteria specified in the different elements such as the examples under each characteristic. For each field, we refer to the concepts with modeling support (Section 4) to describe how this information can be expressed with these concepts and extracted to automatically generate the LINDDUN GO cards.

ID The ID of the card is automatically generated during the extraction of the cards. It does not need to be separately represented in the tree.

Title A single card illustrates a more concrete type of threat and expressed as a *Threat*, from which the title can be directly retrieved as the name of the example.

Description The description of the threat is included in the *description* attribute of the *Threat*.

Questions The questions that determine the applicability of the threat are listed under the *ThreatCharacteristic* leaves. These are combined for all the relevant characteristics that are referred to by the *Threat*.

Examples The examples are directly listed under the *Characteristics* as *CharacteristicExamples*.

By leveraging the same knowledge base, all the information about the examples, criteria, etc. is automatically updated as the threat knowledge continues to be improved over time, eliminating the overhead of maintaining separate artifacts.

6.2.7. LINDDUN GO card browser

In addition to the PDF version, there is a digital version as a LINDDUN GO card browser that allows users to interactive browse through the card deck. This version leveraged the generated images from the GO card deck. Fig. 8(g) shows a screenshot of the LINDDUN GO card browser.

6.2.8. LINDDUN GO digital

The third LINDDUN GO artifact is a fully digital game version. This browser application shuffles the GO card deck, enables filtering, randomly presents the cards, and allows users to document the threats while they navigate through the cards. All card areas are clickable to get additional explanations or examples. Fig. 8(h) shows a screenshot of the LINDDUN GO digital game.

6.2.9. Examples

The final LINDDUN artifact is the collection of more complex LINDDUN privacy threat examples that combine multiple LINDDUN threat characteristics. These examples are expressed as *Threat*s in the metamodel and link to the different characteristics together with the explanation of how these characteristics apply. The examples export comprises of a PDF with for every example the subset of the relevant LINDDUN privacy threat trees (i.e. the subset of the tree with the relevant characteristics used in the example), followed by a detailed explanation for every characteristic. Fig. 9 shows a fragment of the PDF report with the complex threat examples. It shows the relevant threat tree fragments together with the rationale for why the selected nodes apply.

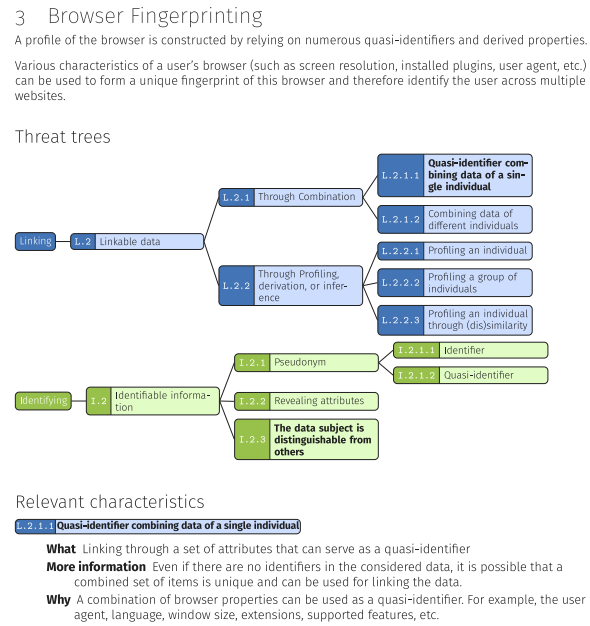


Fig. 9. LINDDUN complex examples export.

6.2.10. Automated artifact generation workflow

A major improvement for managing and creating the different linddun artifacts is the integrated toolchain with the TKM tool. The internal LINDDUN threat knowledge (outlined in Section 6.1) is stored and managed in a git version control repository. This allows tracking the version history, managing changes, tagging different release versions for publication on the LINDDUN website, resolving conflicts.

In addition to the repository, there is a continuous integration pipeline to automatically build all the different LINDDUN artifacts. For release versions, the pipeline injects the release version into the metadata of the generated artifacts. With the continuous integration pipeline, all the different export variants can automatically be constructed and released. All the variants presented in this section are automatically generated from the LINDDUN repository. Fig. 7 showed the overview of this process in which the TKM tool is used for generation of nine different types of export formats (with in additional a number of different variants of a single format such as the threat trees with different numbers of detail in included examples, criteria, impact descriptions, etc.). All the listed variants are available on the LINDDUN website with version URLs to enable users to retrieve the latest as well any particular historic version of the artifacts at a later point in time.[1] This setup provides several benefits in terms of traceability of changes to the threat knowledge, automatically propagating updates to all the relevant artifacts, backwards compatibility by enabling users to refer to specific versions, etc.

Finally, the LINDDUN website (DistriNet, KU Leuven, 2025) also makes available the source files for LINDDUN and the TKM tool which allows users to edit these source files and to generate the different LINDDUN artifacts themselves.

7. Evaluation: LINDDUN practitioner agreement

In this section, we present an experimental evaluation of the new LINDDUN threat knowledge models. We specifically report about two practical applications of LINDDUN by novice practitioners and compare

[1] For example, the basic *linking* tree can be retrieved at https://downloads.linddun.org/linddun-trees/tree-basic/latest/Linking.pdf, the *latest* element in the URL will redirect to the most recent version (e.g., v241203).

Table 3
Overview of the two LINDDUN practitioner studies used in the comparatively evaluation.

Study	Year	Participants	Application case	Applied
#1	2015	10 (14 selected, 4 excluded)	IoT-based home automation system (Van Landuyt and Joosen, 2020) (HomeSys)	old.linddun.org
#2	2023	8 (11 selected, 3 excluded)	Digital consent management system for clinical studies (eConsent)	linddun.org

the respective outputs in terms of the agreement about the privacy threats. Section 7.1 presents the design of the empirical study. Section 7.2 then presents the main quantitative results and discusses the implications and conclusions. Finally, Section 7.3 discusses the threats to validity.

7.1. Study design

This empirical study is aimed at comparing the degree of agreement between novice users of the LINDDUN methodology, more specifically between the older knowledge representations (as discussed in Section 2) and the new LINDDUN threat knowledge models (as described in Section 5.6). We focus on novice, inexperienced users as they will rely most prominently on the provided threat knowledge resources, as opposed to more experienced threat modelers that tend to rely more on expertise and prior experience.

We compare the outcomes of two student studies (summarized in Table 3):

1. The first study (Van Landuyt and Joosen, 2020) was conducted in 2015 and involved 62 participants applying LINDDUN supported by the previous LINDDUN threat knowledge representations (Wuyts and Joosen, 2015). From these, 14 participants have been randomly sampled.
2. The second study was conducted in 2023 and involved 11 participants, yet this time, the participants have been instructed to use the new threat knowledge resources, as introduced in this article.

To ensure data quality, problematic and outlier submissions were excluded from the datasets. These include cases with incomplete reports and empty threat sheets, or outcomes of clear and tangible mistakes against the methodology (e.g., not adhering to the LINDDUN mapping table). In the first study, this led to the exclusion of in total 4 reports whereas in the second study a total of 3 reports were excluded.

In both studies, participants had been given introductory lectures on privacy by design and LINDDUN in particular prior to the privacy threat analysis. In addition, they were provided unrestricted access to the knowledge resources.

The first study was conducted on paper, and participants were given threat templates, assumption sheets and the LINDDUN tutorial leaflet, which consisted of the threat trees, and guidance on how to apply. In this study, the *per-element* variant of LINDDUN was used.

In the second study, participants were given a digital template that they could fill in and hand in digitally. They were given access to the LINDDUN PRO tutorial, the diverse threat tree representations, the encoded examples, the elicitation questions, etc.

In both studies, the involved practitioners (master's students) had no prior experience with privacy threat modeling. The participants were asked to apply LINDDUN to an application case they had become highly familiarized with[2] and reported their analysis results as a set of specific threats.

We compare the outcome threat models obtained in both studies, not in terms of the validity of the resulting threat analyses (e.g., the relevancy of the threats reported), but in terms of the degree of agreement, i.e. the extent to which the participants come to similar conclusions, given the identical inputs they have been provided.

[2] In both cases, the application case was worked on extensively before the study in the context of the educational program.

Table 4
Quantitative results of both studies.

Study	Application	Threats per participant		Agreement		
		Mean	Median	Raters	Fleiss κ	p-value
#1	HomeSys	4.72	4.5	10	0.154	0
#2	eConsent	30	27	8	0.187	0

To statistically evaluate the degree of agreement, we apply kappa tests with a confidence interval of $p < 0.05$. Cohen's kappa is used to measure the inter-rater agreement (pairwise), whereas the overall aggregated agreement among all raters is tested using Fleiss' kappa statistical test.

7.2. Study results

Table 4 presents the main outcomes of this evaluation step. Differences in absolute numbers can be attributed to difference in scope of the system, the complexity of the respective data flow diagrams, and of the actual time spent on the conducted threat modeling effort. In both studies, the overall agreement is low: the kappa values are between 0.1 and 0.2. These results also indicate that there is only a slight, insignificant difference in overall agreement between both studies. We take a number of factors into account:

- The second study was more in-depth and involved a substantially larger set of outcomes (average of 30 threats per participant in the first study as opposed to only 4 in the first). This increases the possibility of disagreement among the practitioners.
- The new threat knowledge representations are more extensive, and they cover a wider and more complex threat landscape: the characterization of the Data Disclosure threat type is entirely novel, and threat characteristics that were previously not addressed or refined have been included in the renewed threat knowledge models (e.g., non-compliance, linking and inference based on data analytics and ML). Because these inputs are more extensive and rich, they may take more effort and time to understand and grasp. These factors increase the potential for disagreement.
- The new knowledge representations now include additional resources that should are aimed at helping the practitioner (e.g., questions, example) that may lead to a more reproducible outcome of threat analysis. This is a factor that is expected to reduce the degree of disagreement.

Given these factors and observations, we posit the main conclusion, i.e. that the new threat knowledge representations at the very least lead to a similar outcome as the earlier version, in terms of the agreement among practitioners. Put differently, the observation that with the updated version of the knowledge resources, no reduction in inter-rater agreement can be shown on its own provides compelling evidence to the benefits of the harmonized and improved privacy threat knowledge.

Further exploring these results, we now present the outcomes of pairwise agreement evaluation, for each combination of participants in each dataset. These more detailed outcomes are depicted in Figs. 10 and 11.

These breakdowns show in closer detail the tendency of more – more kappa values exceeding 0.1 – and more positive (i.e. there are no negative kappa values) agreement in the application case that used the renewed LINDDUN knowledge resources (i.e. the eConsent case).

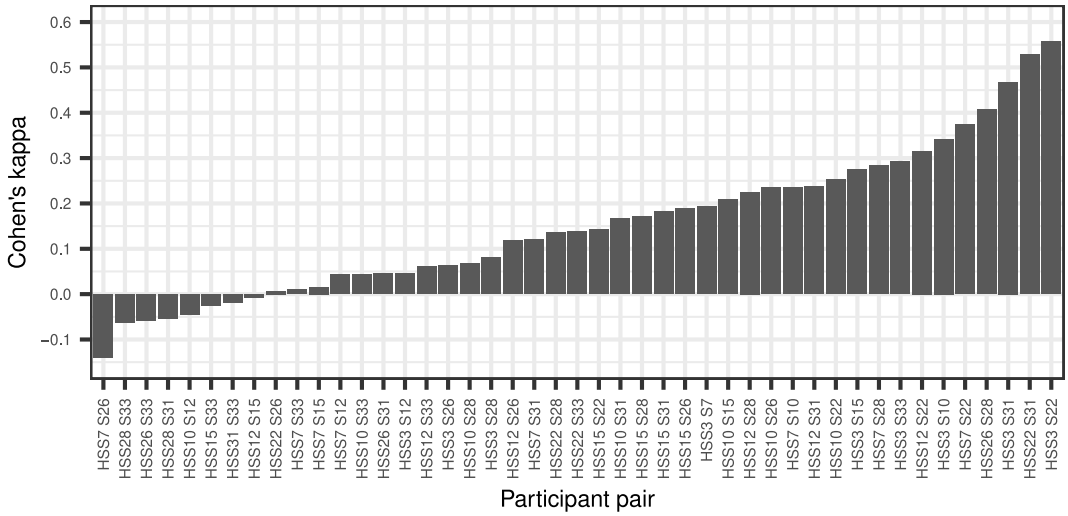


Fig. 10. Pairwise evaluation of inter-rater agreement in the HomeSys case (Cohen's kappa).

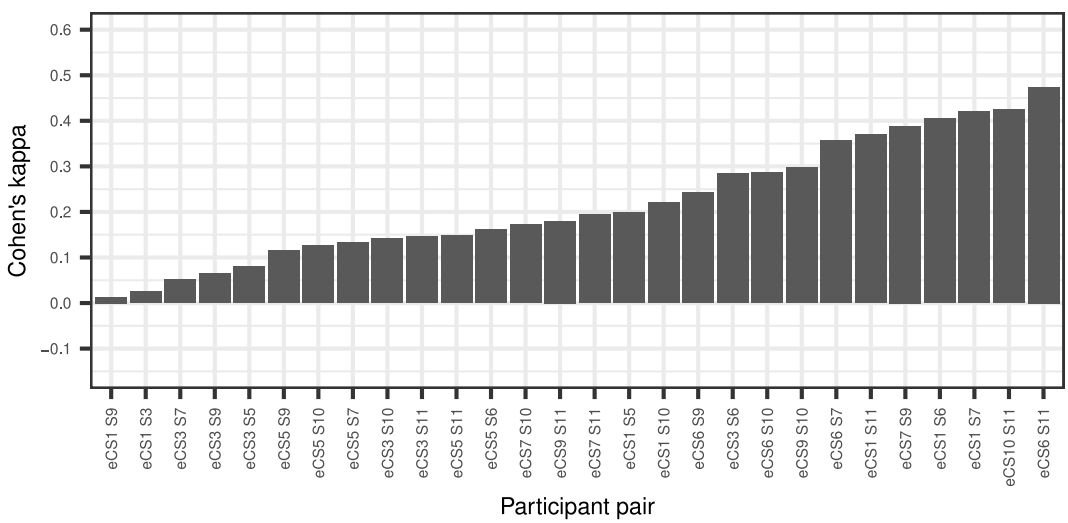


Fig. 11. Pairwise evaluation of inter-rater agreement in the eConsent case (Cohen's kappa).

Finally, we elaborate on the agreement scores on a per-threat-type basis, to identify the types of threat for which the practitioners generally agreed more. A breakdown of the per-threat-type kappa scores are presented in Table 5. Note that the previous threat knowledge resources did not provide any support for Data Disclosure and that none of the participants defined Non-compliance threats, which were defined much more vaguely in the earlier versions. These results show that there is much more agreement about the threat types that were previously defined open-endedly and incompletely (Unawareness, Non-compliance, Non-Repudiation). We can also observe that the broadened scope of the 'Linking' and 'Identifying' threat types has led to lower agreement scores in the new threat knowledge.

Table 5
Breakdown of Fleiss' kappa scores per threat type.
This table shows for every threat type, the inter-rater agreement in the two application cases. The underlined p-values are larger than 0.05.

Threat type	#1: HomeSys		#2: eConsent	
	Fleiss κ	p-value	Fleiss κ	p-value
Linking	0.112	9.01e−06	0.0894	0.0766
Identifying	0.0776	0.00208	−0.00179	0.972
Non-repudiation	−0.0353	0.194	0.316	4.01e−10
Detecting	0.0539	0.0476	0.13	0.0131
Data Disclosure	NA		0.252	6.25e−07
Unawareness & Unintervenability	0.0587	0.379	0.286	0.000723
Non-compliance	NA		0.345	4.41e−05

7.3. Threats to validity

We discuss three potential threats to validity types in the following sections.

7.3.1. Student participants

The studies were performed by novice practitioners, in this case master's students that did not have any prior experience with LINDDUN or privacy threat modeling analysis in general. As discussed above, this is an intentional choice, as it avoids the influence of prior experience and expertise on the outcomes.

However, it may have led to additional threats to validity, as this was a graded assignment, students may have been given an incentive to share or discuss threats and other findings among each other, and this of course could skew the agreement scores. In addition, due to the educational context and the mandatory nature of the assignment, students may not be representative of novice industry practitioners that

are getting acquainted or trained with LINDDUN because they have actual concerns in the design of their applications and services.

In general however, the impact of students on the representativeness of such practitioner studies tends to be overestimated (Falessi et al., 2018). The decision to work with students was additionally also motivated from a practical and pragmatic perspective: it is much more difficult to involve actual industry practitioners (who are high in demand on the job market and thus costly) for these types of studies.

Finally, arguably, involving student threat modelers in the context of this specific evaluation can be considered more valuable, as students will be less likely to resort to established knowledge and expertise and rely maximally on the knowledge resources offered by a threat modeling framework. This allows evaluating the effect of the knowledge resources with a reduced risk of confounding factors.

7.3.2. Differences in study organization

We present a comparative evaluation of the outcomes of two similar, yet distinct studies. The risk arises that a difference in practical organization of context of each study may bias or skew the results.

Time constraints One notable difference is that in the first study, the students were given time constraints: they had to conduct the analysis in a controlled setting in a timeboxed session of 2.5 h. The second study was a take-home assignment, which was conducted in a less controlled manner and students will have spent more time. This difference is reflected in the threat numbers per study. Time pressure may lead to a result in which not all aspects of the system under analysis have been addressed thoroughly. This may have led to a situation in which different parts have been scrutinized by different participants, thus reducing the agreement simply through low coverage of the entire system. We have partially mitigated this threat by excluding a number of submissions that were visibly incomplete (not completely filled in).

Educational context The first study was performed in a course that is part of the general Computer Science master's program, whereas the second study was part of a course in a specialized Master of Cyber Security. Participants of the second study therefore reasonably have a stronger focus (and background) on cybersecurity and privacy, whereas the first group of participants arguable could draw less from such a background. This may have impacted the correct interpretation of the threat knowledge resources and thus may have led to higher overall agreement in the second study. We partially mitigate this by not taking into account at all the validity or correctness of the outcomes, i.e. the relevancy of the threats in the context of the application case.

Per-element vs. per-interaction Finally, the participants of the first study have applied LINDDUN-per-element, as the per-interaction variant only came into existence later (Sion et al., 2018c). In the second study, the participants adopted LINDDUN PRO, which is the per-interaction variant. To make the results comparable, we have condensed the per-interaction table into a per-element table, and this transformation involved loss of information about the specific interaction context in which the threat applies. This conversion may have introduced error or bias, and small differences in placement of threats (i.e. source, flow, or destination) over a single interaction are not picked up in the agreement numbers.

7.3.3. Statistical significance and generalization power

The findings and conclusions are based on two studies with limited participants. The inclusion of additional data points may shift the specific number drastically. Different applications may lead to very different observations. Extending the empirical basis in larger and more controlled studies is considered part of future work.

We refrain from making strong conclusions about incidental minor differences, but we observe that the agreement scores are in the same region in both studies (generally low), and thus that the more grounded, extensive and complete threat knowledge resources presented in this paper have not led to a reduction in agreement between practitioners.

8. Related work

Approaches and efforts to consolidate privacy threat knowledge are diverse and broad. The related work is grouped together in the following parts: (i) privacy concepts, (ii) privacy threat knowledge, (iii) privacy solutions, and (iv) privacy risk models.

8.1. Privacy concepts, metamodels, and ontologies

Over time, privacy as a system design goal has been refined in literature into its many facets.

One of the first breakdowns is the seminal work from Pfitzmann and Köhntopp (2001) and Pfitzmann and Hansen (2010) that has been continually refined and updated between 2001 and 2010. They include *anonymity* (the inability of the attacker to identify the data subject within a set of data subjects), *unobservability* (the inability of an attacker to distinguish items of interest from other items or random noise), *pseudonymity* (the use of identifiers that not directly convey identity), and *unlinkability* (the inability of associate data elements across domains or applications).

The ISO/IEC 15408, Part 2:2012 (Common Criteria, 2012) has released the 'Common Criteria for Information Technology Security Evaluation' which contributes a highly detailed breakdown of actionable security requirements on the one hand, but also focuses on privacy aspects of anonymity, pseudonymity, unlinkability, and unobservability.

Spiekermann and Cranor (2009) further refine the notion of user identifiability and define a number of privacy stages, ranging from identified, pseudonymous and anonymous. Their seminal work further discusses the different approaches to privacy: privacy-by-policy and privacy-by-architecture or -by-design.

The Standard Data Protection Model (SDM) (ULD, 2017) defined the German Data Protection Authorities (the *Independent Data Protection Supervisory Authorities of the Federation and the Länder*) provides a methodology to translate the GDPR principles and stipulations into concrete technical (and organizational) measures. The main protection goals identified as such are data minimization, availability, integrity, confidentiality, unlinkability, transparency, intervenability.

The conceptual refinement of privacy as an overarching notion into a number of more clearly defined subgoals is essential to increase understanding and awareness. However, as with security, a converse approach focusing on misuse, harm, negative outcomes and risks is more valuable in terms of defining priorities, defenses, and mitigations and making privacy actionable during system engineering.

A very extensive ontology for expressing personal data, how it is used and protected, and the related legal aspects (legal basis, rights, etc.), is the Data Privacy Vocabulary (DPV) (Pandit et al., 2019, 2025). While the original version (DPV 1.0) was constructed in the context of the GDPR (European Union, 2016), the more recent version DPV 2.0 takes into account multiple jurisdictions, technologies, and a broader scope of legislation. Given the focus on representing what types of data are processed and how, this information is very complementary to the threat analysis to identify ways in which this can lead to different types of privacy threats.

Another relevant ontology is COPri v.2 (Gharib et al., 2021), which focuses on privacy requirements. The ontology is constructed from a systematic literature review and implemented in Protégé. COPri contains concepts along four dimensions: organizational (involved actors, information, use, etc.), risk (vulnerabilities and threats), treatment

(goals, constraints, policy, and mechanisms), and the privacy dimension (with privacy goals such as anonymity and unobservability). Our presented metamodel is complementary to this as it focuses explicitly on deepening the privacy dimension but from a threat rather than goal perspective.

8.2. Privacy impact, weaknesses, harms, and threats

In '*A Taxonomy of Privacy*' (Solove, 2005) has introduced a comprehensive breakdown of the negative outcomes and harms that can be attributed to the disregard of privacy as an overall system goal. This broad list of negative outcomes includes practices such as appropriation, discrimination, exclusion, etc. While this is a very comprehensive taxonomy, there is no methodological support to concretize these into concrete threats or risks within the scope of an architecture or design. In that sense it is complementary to system-level analysis approaches that reason about privacy threats that can subsequently be assessed in the privacy harms that they enable.

Privacy threat modeling involves systematic investigation of potential privacy threats, i.e. scenarios in which a negative privacy outcome can be attained. The LINDDUN characterizations of privacy knowledge prior to the effort described in this article, i.e. the LINDDUN privacy trees (Deng et al., 2011; Wuyts, 2015) have been discussed in Section 2 and illustrated in Figs. 1(a) and 1(b).

The most interesting consolidations of privacy threat knowledge can be found in concrete tool implementations (Continuum Security, 2018; Microsoft Corporation, 2020). Tools such as the Microsoft Threat Modeling Tool (Microsoft Corporation, 2020) allow threats to be documented by filling a parameterized template of a threat, but this is done when the threat has already been identified. OWASP Threat-Dragon (OWASP, 2025) features LINDDUN privacy threat modeling support, but this is limited to just supporting the proper labeling of threats with one of the LINDDUN threat types. These characterizations of threats lack information on how to identity threats, i.e. by providing the threat modeler with a number of questions or giving leading examples.

A privacy design flaw (Arvesen, 2022; Tuma et al., 2020, 2019) (also called 'design weakness' (De and Le Métayer, 2016) or 'design defect') refers to a generic and frequent architectural issue that affects privacy. Existing weakness databases such as the Common Weakness Enumeration (CWE) (MITRE, 2023d) focus predominantly on security issues. Vulnerabilities in turn are concrete issues with specific software products or implementation. As with weaknesses, they are typically collected with emphasis on security issues (e.g., the Common Vulnerability Enumeration (CVE) (MITRE, 2023c)), and similar efforts for privacy are still lagging behind. Related to this is the consolidation of common design issues, such as in the OWASP top 10 (OWASP, 2021).

Different types of consolidation of reusable security or privacy knowledge are attack patterns (MITRE, 2023b,a) which codify common incremental attack approaches used by adversaries. These types of knowledge focus on causality of operations (e.g., first a user is spoofed, then their personal data is obtained or tampered with), whereas threat modeling approaches focus on articulating individual threats.

Another recently introduced privacy knowledge resources is MITRE's PANOPTIC (Shapiro et al., 2023). Contrary to the other MITRE resources such as CAPEC and ATT&CK, it focuses specifically on privacy. PANOPTIC uses two taxonomies: privacy contextual domains and privacy activities and is constructed from knowledge about FTC/FCC privacy attacks.

Finally, attack trees (Schneier, 1999) are a representation of the actual analysis outcome, where the analysis approach starts from a possible attacker end goal and then systematically breaks this down into steps that may be taken by an attacker to meet this goal. This approach does not provide reusable knowledge resources to aid in the actual analysis.

8.3. Privacy risk models

A further and necessary concretization of privacy threats happens when they are prioritized and ranked in terms of the risk they impose on the system. Stepping away from simplistic approaches acting upon more subjective or ad hoc prioritization schemes (for example, describing likelihood and impact in the [low, medium, high] ordinal scale), a number of efforts have been made to identity *risk factors* or *risk components*, i.e. specific and concrete elements that contribute to risk or severity.

FAIR, referring to the Factor Analysis of Information Risk (Freund and Jones, 2014) proposes an holistic approach to more systematically express risks, based on factor decomposition, scenario creation, and stakeholder involvement. While complete and holistic, this approach does not provide guidance or support specific to concretizing privacy risk. Cronk and Shapiro (2021) present a FAIR-based approach to quantify privacy risk. This risk model expresses severity of harm and tangible outcomes, differentiating between impact on individuals, society, with focus on harmful malpractices such as social ranking, differential access, and class discrimination.

The PRIAM approach of De and Le Métayer (2016) and Alshammari and Simpson (2018) allows the creation of complex privacy risk models and their further decomposition into a number of risk factors contributing to either impact or likelihood. These risk factors are expressed either qualitatively or quantitatively.

The work of Sion et al. (2019b) focuses on expressing data subject types and the different properties of relevant data subjects in DFDS and as such takes a first step towards a better articulation of dominant factors that influence privacy threat severity (e.g., data subject age, data sensitivity).

We envision that the further concretization of privacy threat types as proposed in this article, and their refinement into more concrete threat characteristics will greatly benefit the efforts to quantify and qualify actual risks. Based on the applicability and interplay between threat characteristics (some may dampen each other, others may reinforce), a more concrete assessment of privacy risks can be accomplished.

9. Conclusion and future work

Privacy as a key software design notion covers a number of non-trivial concepts that are inherently difficult to fully grasp by non-experts. While these are generally better understood by experts, privacy threats remain intrinsically complex to imagine and instantiate by practitioners, architects, developers, and privacy engineers. Indeed, the generally low degree of inter-rater agreement (discussed in Section 7) illustrates the complexity in applying this knowledge while performing privacy threat analysis: different practitioners still come to different conclusions. Additionally, existing conceptual frameworks, threat knowledge repositories, and methodologies are too static and rigid, and thus hard to evolve or customize, and generally lack flexibility to be used in a range of different approaches.

In line with the overall limitations of the state-of-the-art, the pre-existing privacy threats of LINDDUN are not immune to these problems and limitations. For example, the derivation of threat cards in the earlier LINDDUN GO variant (Wuyts et al., 2020) was performed separately from the threat knowledge resources of the LINDDUN-per-element (Wuyts, 2015) or -per-interaction (Sion et al., 2018c) variants.

In this article, we present our approach to fundamentally rethink and restructure threat characterizations and the resulting framework for privacy threat knowledge. This framework caters for (i) extension and evolution over time (in terms of characteristics, examples), (ii) adoption (i.e. make actionable) in various analysis approaches.

We discuss and motivate on the one hand the refined and improved knowledge modeling approach (in terms of the metamodels and core concepts of the knowledge graphs), and on the other hand describe in

depth the technological enablers that were created to flexibly export and derive different artifacts in a fully automated manner. The novel approach is validated and showcased in the demonstration of the automated derivation of diverse knowledge outputs, ranging from card decks, web catalogs, trees, leaflets, etc.

A major outcome of this work is a significant improvement of the LINDDUN threat modeling framework. The new version presented in this article covers major improvements: (i) it attains a new level of concretization and clarity in defining threat types and their characteristics, augmented with additional knowledge such as examples and elicitation questions and (ii) it is now supported with novel and dedicated tooling support to process this knowledge.

The groundwork that has been presented in this paper opens up the possibility of a number of relevant tracks for future work.

External tool integration. As a side-effect of the consolidation efforts described in this article, the technical integration of the LINDDUN privacy threat knowledge into other threat modeling tools such as OWASP ThreatDragon (OWASP, 2025) or pytm (Tarandach, 2023) has now become feasible. This will allow the users of these tools to benefit from the diverse knowledge artifacts (e.g., illustrative examples).

Application to STRIDE. We have applied the modeling approach to consolidate privacy threat knowledge for LINDDUN. However, a similar treatment can be applied to consolidate and make reusable the knowledge resources that underpin the STRIDE methodology for security threat modeling. Apart from all the benefits discussed in this paper, this would make both approaches more compatible with each other and support the combined evaluation of both security and privacy threats.

Automated and tailored threat elicitation. The current knowledge representation includes metadata indicating the applicability of the knowledge (e.g., hotspots in threat cards, applicability criteria, etc.). These are (currently) predominantly meant for the human threat modeler. The more extensive consolidation of knowledge related to each threat characteristic also opens up the opportunity to include executable logical expressions (e.g., model patterns) that allow evaluating the applicability of these specific conditions. These can then be used in support of automated threat elicitation and generation approaches. By evaluating such logical expressions over a system model, a more sophisticated, model-pattern-based approach can be supported that is more effective in identifying relevant issues.

Domain refinements. The current knowledge base is versatile and reusable in the sense that it can be applied in a wide variety of applications and application domains. Earlier versions of LINDDUN have presented techniques to create and support domain-specific versions of LINDDUN (Wuyts et al., 2018) but this support remained ad hoc. More recently, the value and necessity to create variants that are specialized in specific application domains has been confirmed (Sion et al., 2025) and recent literature provides many examples of 'domain-specific privacy threat models' established with LINDDUN (Raciti and Bella, 2023; Cui et al., 2022; Mirzamohammadi et al., 2023; Park et al., 2018). The modeling support presented in this article will greatly facilitate the definition of domain-specific refinements, and these in turn will lead to efficiency gains as the threat modeler should not spend time and effort on threat types and examples that are too distant from their application.

Extensive empirical evaluation. While first steps in this direction were taken in Section 7, further empirical research and user studies are required to validate the improvement in efficiency, understandability, and customizability of the threat knowledge resources, by both novice and experienced threat modelers. Amongst other activities, a scientific comparison of the effectiveness of the different methodological variants (e.g., card-based or DFD-based) can now be done more correctly, since they are now based on the exact same knowledge structures.

CRediT authorship contribution statement

Laurens Sion: Writing – review & editing, Writing – original draft, Visualization, Validation, Software, Methodology, Investigation, Data curation, Conceptualization. **Dimitri Van Landuyt:** Writing – review & editing, Validation, Investigation, Data curation, Conceptualization. **Kim Wuyts:** Validation, Conceptualization. **Wouter Joosen:** Writing – review & editing, Supervision, Project administration, Funding acquisition, Conceptualization.

Declaration of competing interest

The authors declare the following financial interests/personal relationships which may be considered as potential competing interests: Laurens Sion reports financial support was provided by Cybersecurity Research Program Flanders. Dimitri Van Landuyt reports financial support was provided by Cybersecurity Research Program Flanders. Kim Wuyts reports financial support was provided by Cybersecurity Research Program Flanders. If there are other authors, they declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Acknowledgments

This research is partially funded by the Research Fund KU Leuven, and by the Cybersecurity Research Program Flanders.

Appendix. Description of case studies

A.1. Contact-tracing application

A system for secure and privacy-preserving proximity tracing at large scale. This system provides a technological foundation to help slow the spread of SARS-CoV-2 by simplifying and accelerating the process of notifying people who might have been exposed to the virus so that they can take appropriate measures to break its transmission chain. The system aims to minimize privacy and security risks for individuals and communities and guarantee the highest level of data protection.

The goal of our proximity tracing system is to determine who has been in close physical proximity to a COVID-19 positive person and thus exposed to the virus, without revealing the contact's identity or where the contact occurred. To achieve this goal, users run a smartphone app that continually broadcasts an ephemeral, pseudo-random ID representing the user's phone and also records the pseudo-random IDs observed from smartphones in close proximity. When a patient is diagnosed with COVID-19, she can upload pseudo-random IDs previously broadcast from her phone to a central server. Prior to the upload, all data remains exclusively on the user's phone. Other users' apps can use data from the server to locally estimate whether the device's owner was exposed to the virus through close-range physical proximity to a COVID-19 positive person who has uploaded their data. In case the app detects a high risk, it will inform the user.

A.2. Whistleblower submission system

SecureDrop is an open-source whistleblower submission system that media organizations can use to securely accept documents from and communicate with anonymous sources. SecureDrop is a tool for sources to communicate securely with journalists. The SecureDrop application environment consists of three dedicated computers: Secure Viewing Station (A physically-secured and air-gapped laptop running the Tails operating system from a USB stick, that journalists use to decrypt and view submitted documents.), Application Server (An Ubuntu server running two segmented Tor hidden services. The source connects to the Source Interface, a public-facing Tor Onion Service, to send messages and documents to the journalist. The journalist connects to the Journalist Interface, an authenticated Tor Onion Service, to download encrypted documents and respond to sources.), Monitor Server (An Ubuntu server that monitors the Application Server with OSSEC and sends email alerts.) (Freedom of the Press Foundation, 2018).

A.3. Remote measuring, monitoring, and control system

The project involves the development of a remote measurement, monitoring and control system (shortened as ReMeS) for a variety of devices

The main goal of the system is to bring added value to the customers of our firm, the utility providing companies. This is mainly done by reducing their running costs and the administrative overhead related to measuring user consumption. In order to achieve this high-level goal, ReMeS should realize (at least) the following goals: remote measurements, leak and anomaly detection (alarm notifications, remote valve control), consumption prediction (consumption advice, utility production planning) and billing/invoicing.

Data availability

Data will be made available on request.

References

Alshammari, M., Simpson, A., 2018. Towards an effective privacy impact and risk assessment methodology: risk assessment. In: Trust, Privacy and Security in Digital Business: 15th International Conference, TrustBus 2018, Regensburg, Germany, September 5–6, 2018, Proceedings 15. Springer, pp. 85–99.

Arvesen, E., 2022. Privacy design flaws. USENIX Association, Santa Clara, CA.

Barberá, I., 2024. PLOT4ai - Privacy library of threats 4 artificial intelligence. URL https://plot4.ai/.

Braiterman, Z., Shostack, A., Marcil, J., de Vries, S., Michlin, I., Wuyts, K., Hurlbut, R., Schoenfield, B.S., Scott, F., Coles, M., Romeo, C., Miller, A., Tarandach, I., Douglen, A., French, M., 2020. Threat modeling manifesto. https://www.threatmodelingmanifesto.org/.

Brooks, S., Garcia, M., Lefkovitz, N., Lightman, S., Nadeau, E., 2017. An Introduction to Privacy Engineering and Risk Management in Federal Systems. Tech. Rep. NIST IR 8062, National Institute of Standards and Technology, Gaithersburg, MD, http://dx.doi.org/10.6028/NIST.IR.8062, NIST IR 8062. URL https://nvlpubs.nist.gov/nistpubs/ir/2017/NIST.IR.8062.pdf.

Common Criteria, 2012. Common criteria for information technology security evaluation part 2: security functional components. In: ISO/ IEC 15408 Common Criteria, Part 2: 2012. pp. 1–321, (September).

Continuum Security, 2018. Irius risk. URL https://community.iriusrisk.com.

Cronk, R.J., Shapiro, S., 2021. Quantitative privacy risk analysis. In: 2021 IEEE Security and Privacy Workshops. SPW, IEEE, pp. 335–345.

Cui, D., Quan, Z., Piao, Y., 2022. An effective method for privacy concerns on digital contact tracing protocols. In: 2022 5th International Conference on Pattern Recognition and Artificial Intelligence (PRAI). IEEE, pp. 1125–1129.

De, S.J., Le Métayer, D., 2016. PRIAM: A privacy risk analysis methodology. Lecture Notes in Comput. Sci. 221–229.

DeMarco, T., 1979. Structured Analysis and System Specification. Yourdon Press.

Deng, M., Wuyts, K., Scandariato, R., Preneel, B., Joosen, W., 2011. A privacy threat analysis framework: supporting the elicitation and fulfillment of privacy requirements. Requir. Eng. 16 (1).

DistriNet, KU Leuven, 2025. LINDDUN website. https://www.linddun.org/.

European Union, 2016. Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation). Off. J. the EU 59 (L 119), 1–88.

Falessi, D., Juristo, N., Wohlin, C., Turhan, B., Münch, J., Jedlitschka, A., Oivo, M., 2018. Empirical software engineering experts on the use of students and professionals in experiments. Empir. Softw. Eng. 23, 452–489.

Freedom of the Press Foundation, 2018. SecureDrop | The open-source whistleblower submission system. URL https://securedrop.org/.

Freund, J., Jones, J., 2014. Measuring and Managing Information Risk: a FAIR Approach. Butterworth-Heinemann.

Funk, M., 2020. Assessing privacy risk with the IPA triad. In: 2020 USENIX Conference on Privacy Engineering Practice and Respect (PEPR 20). USENIX Association, URL https://www.usenix.org/conference/pepr20/presentation/funk.

Gharib, M., Giorgini, P., Mylopoulos, J., 2021. COPri v.2 — A core ontology for privacy requirements. Data Knowl. Eng. 133, 101888. http://dx.doi.org/10.1016/j.datak.2021.101888, URL https://www.sciencedirect.com/science/article/pii/S0169023X2100015X.

Hartzog, W., 2018. Privacy's Blueprint. Harvard University Press, http://dx.doi.org/10.4159/9780674985124.

Hoepman, J.-h., 2014. Privacy design strategies. In: Thierry Cuppens-Boulahia, N., Cuppens, F., Jajodia, S., Abou El Kalam, A., Sans (Eds.), ICT Systems Security and Privacy Protection: 29th IFIP TC 11 International Conference, SEC 2014, Marrakech, Morocco, June 2-4, 2014. Proceedings. Springer Berlin Heidelberg, pp. 446–459. http://dx.doi.org/10.1007/978-3-642-55415-5_38.

Howard, M., Lipner, S., 2006. The Security Development Lifecycle. Microsoft Press.

Hu, H., Salcic, Z., Sun, L., Dobbie, G., Yu, P.S., Zhang, X., 2022b. Membership inference attacks on machine learning: A survey. ACM Comput. Surv. 54 (11s), 1–37.

International Organization for Standardization, 2019. Information Technology — Security Techniques — Privacy Engineering for System Life Cycle Processes. Technical Report 27550, ISO/IEC, p. 52, ICS: 35.030.

International Organization for Standardization, 2023. Consumer Protection — Privacy by Design for Consumer Goods and Services. Standard 31700, ISO, p. 37.

Kohnfelder, L., Garg, P., 1999. The threats to our products. Interface (Microsoft Corporation).

Lederer, S., Hong, J.I., Dey, A.K., Landay, J.A., 2004. Personal privacy through understanding and action: five pitfalls for designers. Pers. Ubiquitous Comput. 8 (6), 440–454, URL https://doi.org/10.1007/s00779-004-0304-9.

Microsoft Corporation, 2016. Microsoft threat modeling tool 2016. http://aka.ms/tmt2016.

Microsoft Corporation, 2020. Microsoft threat modeling tool 7. http://aka.ms/tmt.

Mirzamohammadi, O., Jannes, K., Sion, L., Van Landuyt, D., Abidin, A., Singelée, D., 2023. Security and Privacy Threat Analysis for Solid. IEEE Softw., Special Issue on Software Protection 1 (1), 1–11.

MITRE, 2023a. ATT&CK. URL https://attack.mitre.org/.

MITRE, 2023b. CAPEC - Common attack pattern enumeration and classification. URL https://capec.mitre.org.

MITRE, 2023c. CVE - Common vulnerabilities and exposures. URL https://cve.mitre.org.

MITRE, 2023d. CWE - Common weakness enumeration. URL https://cwe.mitre.org.

NIST, 2020. NIST Privacy Framework: A Tool for Improving Privacy through Enterprise Risk Management. Tech. rep., NIST, p. 43, URL https://www.nist.gov/system/files/documents/2020/01/16/NIST%20Privacy%20Framework_V1.0.pdf.

OWASP, 2021. Top 10 web application security risks. https://owasp.org/www-project-top-ten/.

OWASP, 2025. Threat dragon. https://owasp.org/www-project-threat-dragon/.

Pandit, H.J., Esteves, B., P. Krog, G., Ryan, P., Golpayegani, D., Flake, J., 2025. Data privacy vocabulary (DPV) – version 2.0. In: Demartini, G., Hose, K., Acosta, M., Palmonari, M., Cheng, G., Skaf-Molli, H., Ferranti, N., Hernández, D., Hogan, A. (Eds.), The Semantic Web – ISWC 2024. Springer Nature Switzerland, Cham, pp. 171–193.

Pandit, H.J., Polleres, A., Bos, B., Brennan, R., Bruegger, B., Ekaputra, F.J., Fernández, J.D., Hamed, R.G., Kiesling, E., Lizar, M., Schlehahn, E., Steyskal, S., Wenning, R., 2019. Creating a vocabulary for data privacy. In: Panetto, H., Debruyne, C., Hepp, M., Lewis, D., Ardagna, C.A., Meersman, R. (Eds.), On the Move To Meaningful Internet Systems: OTM 2019 Conferences. Springer International Publishing, Cham, pp. 714–730.

Park, J.-H., Kang, S.-y., Kim, S.-j., 2018. Study of security requirement of smart home hub through threat modeling analysis and common criteria. J. Korea Inst. Inform. Security Cryptol. 28 (2), 513–528.

Patil, S., Kobsa, A., 2009. Privacy considerations in awareness systems: Designing with privacy in mind. In: Markopoulos, P., De Ruyter, B., Mackay, W. (Eds.), Awareness Systems: Advances in Theory, Methodology and Design. Springer London, London, pp. 187–206, URL https://doi.org/10.1007/978-1-84882-477-5_8.

Pfitzmann, A., Hansen, M., 2010. A terminology for talking about privacy by data minimization: Anonymity, unlinkability, undetectability, unobservability, pseudonymity, and identity management.

Pfitzmann, A., Köhntopp, M., 2001. Anonymity, unobservability, and pseudonymity — A proposal for terminology. In: Federrath, H. (Ed.), Designing Privacy Enhancing Technologies: International Workshop on Design Issues in Anonymity and Unobservability Berkeley, CA, USA, July 25–26, 2000 Proceedings. Springer Berlin Heidelberg, Berlin, Heidelberg, pp. 1–9, URL https://doi.org/10.1007/3-540-44702-4_1.

Raciti, M., Bella, G., 2023. Up-to-date threat modelling for soft privacy on smart cars. In: European Symposium on Research in Computer Security. Springer, pp. 454–473.

Roe, M., 2010. Cryptography and Evidence. Tech. Rep. UCAM-CL-TR-780, University of Cambridge, Computer Laboratory.

Schneider, C., 2023. Threagile. https://threagile.io/.

Schneier, B., 1999. Attack trees.

Shapiro, S., Bloom, C., Ballard, B., Slotter, S., Paes, M., McEwen, J., Xu, R., Katcher, S., 2023. The PANOPTIC™ Privacy Threat Model. Tech. Rep. Version 1.

Shokri, R., Stronati, M., Song, C., Shmatikov, V., 2017. Membership inference attacks against machine learning models. In: 2017 IEEE Symposium on Security and Privacy. SP, IEEE, pp. 3–18.

Shostack, A., 2014a. Threat Modeling: Designing for Security. John Wiley & Sons, Indianapolis, Indiana, p. 590.

Shostack, A., 2014b. Elevation of privilege: drawing developers into threat modeling. In: 2014 USENIX Summit on Gaming, Games, and Gamification in Security Education. 3GSE 14, URL https://www.usenix.org/conference/3gse14/summit-program/presentation/shostack.

Sion, L., Tuma, K., Yskout, K., Scandariato, R., Joosen, W., 2019a. Towards automated security design flaw detection. In: 2019 34th IEEE/ACM International Conference on Automated Software Engineering Workshop. ASEW, pp. 49–56.

Sion, L., Van Landuyt, D., Joosen, W., Leveraging the domain experts: specializing privacy threat knowledge, in: Computer Security, ESORICS 2024 International Workshops.

Sion, L., Van Landuyt, D., Wuyts, K., Joosen, W., 2019b. Privacy risk assessment for data subject-aware threat modeling. In: 2019 IEEE Security and Privacy Workshops. SPW, IEEE, pp. 64–71.

Sion, L., Van Landuyt, D., Yskout, K., Joosen, W., 2018a. SPARTA: Security & privacy architecture through risk-driven threat assessment. In: 2018 IEEE International Conference on Software Architecture Companion. ICSA-C, IEEE, pp. 89–92.

Sion, L., Wuyts, K., Yskout, K., Van Landuyt, D., Joosen, W., 2018. Interaction-based privacy threat elicitation. In: 2018 IEEE European Symposium on Security and Privacy Workshops. EuroS&PW, IEEE, pp. 79–86.

Sion, L., Wuyts, K., Yskout, K., Van Landuyt, D., Joosen, W., 2018c. Interaction-based privacy threat elicitation. In: 2018 IEEE European Symposium on Security and Privacy Workshops. EuroS&PW, IEEE, pp. 79–86.

Solove, D.J., 2005. A taxonomy of privacy. Univ. Pa. Law Rev. 154 (3), 477–564.

Spiekermann, S., Cranor, L.F., 2009. Engineering privacy. IEEE Trans. Softw. Eng. 35 (1), 67–82.

Steinberg, D., Budinsky, F., Merks, E., Paternostro, M., 2008. EMF: Eclipse Modeling Framework. Pearson Education.

Sweeney, L., 2000. Simple demographics often identify people uniquely. Heal. (San Francisco) 671 (2000), 1–34.

Swiderski, F., Snyder, W., 2004. Threat Modeling. Microsoft Press.

Tarandach, I., 2023. PyTM. https://github.com/izar/pytm.

Tuma, K., Scandariato, R., Balliu, M., 2019. Flaws in flows: Unveiling design flaws via information flow analysis. In: 2019 IEEE International Conference on Software Architecture. ICSA, pp. 191–200. http://dx.doi.org/10.1109/ICSA.2019.00028.

Tuma, K., Sion, L., Scandariato, R., Yskout, K., 2020. Automating the Early Detection of Security Design Flaws. In: 23rd International Conference on Model Driven Engineering Languages and Systems. MODELS.

ULD, 2017. The standard data protection model: A concept for inspection and consultation on the basis of unified protection goals.

Van Landuyt, D., Joosen, W., 2020. A descriptive study of assumptions made in LINDDUN privacy threat elicitation. In: Proceedings of the 35th Annual ACM Symposium on Applied Computing. pp. 1280–1287.

Westin, A., 1967. Privacy and Freedom. Ig Publishing, New York.

Wuyts, K., 2015. Privacy Threats in Software Architectures (Ph.D. thesis). KU Leuven.

Wuyts, K., Joosen, W., 2015. LINDDUN privacy threat modeling: a tutorial.

Wuyts, K., Scandariato, R., Joosen, W., 2014. LINDDUN threat tree catalog (v2.0). https://old.linddun.org/_files/ugd/cc602e_d7cf949767b7486d8bff0ecc05b91db6.pdf..

Wuyts, K., Sion, L., Joosen, W., 2020. LINDDUN GO: A Lightweight Approach to Privacy Threat Modeling. In: 2020 IEEE Security and Privacy Workshops. SPW, IEEE.

Wuyts, K., Van Landuyt, D., Hovsepyan, A., Joosen, W., 2018. Effective and Efficient Privacy Threat Modeling through Domain Refinements. In: SAC2018: 1st Track on Privacy By Design. PbD.

Xiong, W., Lagerström, R., 2019. Threat modeling – A systematic literature review. Comput. Secur. 84, 53–69. http://dx.doi.org/10.1016/j.cose.2019.03.010.